



辽宁移动培训专用

安全意识及数据安全专项能力提升培训

2023年10月

目录

- 1 网络安全基础
- 2 网络信息安全意识提升
- 3 法律法规与案例解析
- 4 信息安全工作
- 5 数据安全基础
- 6 数据安全技术及发展

网络安全基础

案例：

- 哈马斯以色列冲突持续, 全球黑客站队, 掀起“第二战场”
- 10月7日凌晨, 巴勒斯坦伊斯兰抵抗运动 (哈马斯) 宣布对以色列发动军事行动, 数以千枚的火箭弹从加沙地带呼啸奔向以色列各大城镇, 其武装人员从海陆空潜入与以军发生冲突。
- 全球黑客组织正在“选边站队”, 对以色列和巴勒斯坦数字基础设施开展网络攻击, 在网络空间塑造了巴以冲突的第二战场。

包括“孟加拉国神秘团队” (Mysterious Team Bangladesh)、 “匿名者苏丹” (Anonymous Sudan)、 “巴基斯坦疯狂团队” (Team Insane Pakistan)、 “Garnesia团队” (Garnesia Team)、 “甘诺赛团队” (Ganosecteam) 等在内的伊斯兰黑客组织发起了代号为OPISRAEL和OplsrailV2的行动, 针对包括以色列国家电力局、政府网站、等数字基础设施的攻击行动。



美国NSA对西工大发起网络攻击事件

网络攻击西工大的TAO，身份是这样暴露的

播报文章



北京日报客户端

2022-09-27 12:14

北京日报报业集团

关注

长安街知事微信公众号 | 记者 蒙江

美国NSA对西工大发起网络攻击事件，又有新的细节公开。

9月27日，国家计算机病毒应急处理中心发布《西北工业大学遭美国NSA网络攻击事件调查报告（之二）》，披露了美国国家安全局（NSA）“特定入侵行动办公室”（TAO）攻击渗透西北工业大学的流程、窃取西北工业大学和中国运营商敏感信息，公布了TAO网络攻击西北工业大学武器平台IP列表及所用跳板IP列表。

美国NSA对西工大发起网络攻击事件

- 从国家计算机病毒应急处理中心和360获悉，在侦办西北工业大学网络攻击案过程中，我方成功提取了名为“**二次约会**”(SecondDate)“**间谍**”软件的多个样本。
- 据“影子经纪人”泄露的NSA内部文件，该“间谍”软件为**NSA开发的网络武器**，其主要部署在目标网络边界设备(网关、防火墙、边界路由器等)，隐蔽监控网络流量，并根据需要精准选择特定网络会话进行重定向、劫持、篡改。

小知识：

影子经纪人，是一个比较神秘的黑客组织。2016年，成功黑掉了“方程式小组”，并使“方程式小组”的黑客工具大量泄漏。 [1]2017年5月，影子经纪人称将放出更多美国国安局病毒代码。

美国NSA对西工大发起网络攻击事件

TAO对他国发起的网络攻击技战术针对性强，采取**半自动化**攻击流程

- 单点突破、级联渗透，控制西北工业大学网络；
- 隐蔽驻留、“合法”监控，窃取核心运维数据；
- 搜集身份验证数据、构建通道，渗透基础设施；
- 控制重要业务系统，实施用户数据窃取。

中间人攻击
酸狐狸（漏洞）
怒火喷射（远控）

TAO利用窃取到的网络设备账号口令，以“合法”身份进入中国某基础设施运营商服务网络，控制相关服务质量监控系统，窃取用户隐私数据。

TAO利用相同的武器工具组合，“合法”控制了全球不少于80个国家的**电信基础设施网络**。

案例：富士康被黑客勒索

🏠 搜狐 | 新闻 体育 汽车 房产 旅游 教育 时尚 科技 财经



黑客技术与网络安全



富士康被黑客攻击，索要 2.3 亿元赎金：已加密约 1200 台服务器，窃取了 100 GB 的未加密文件，并删除 20 ~ 30 TB 的备份

2020-12-14 08:30

- 网络安全行业的消息人士已证实，富士康于2020年11月29日左右在位于墨西哥华雷斯城的富士康CTBG MX生产设施遭到了攻击。
- 该生产设施于2005年开业，被富士康用来将电子设备组装和运输到南美和北美的所有地区。富士康CTBG MX官网页面这样介绍该生产设施：“我们占地682000平方英尺的工厂建于2005年，位于墨西哥奇瓦瓦州华雷斯城，对面就是得克萨斯州埃尔帕索。富士康CTBG MX的位置具有重要的战略意义，支持美洲所有地区。”

案例：

美国移动通信公司遭黑客入侵，泄漏约3700万客户信息

🔊 播报文章



鞭牛士

2023-01-20 08:37 | 鲲鹏计划获奖作者

关注

鞭牛士 1月20日消息，据央视新闻报道，当地时间1月19日，美国移动通信公司（T-Mobile）表示，有黑客入侵该公司系统并获取了约3700万名客户的数据，包括客户出生日期和账单地址。

该公司在一份监管申报文件中称，在当地时间1月5日发现了这次入侵，目前正在与执法人员和网络安全顾问合作解决。

美国移动通信公司认为，黑客自11月25日就开始访问其数据，但当时未能成功入侵。

暗网中个人信息买卖

主题帖交易信息一览

交易编号:	14434	商品单价:	17 [美元]	交易发布时间:	2018-10-30 17:19	加入收藏
卖家账号:	66960	单价折算:	0.00215 [比特币]	商家最后在线:	2020-03-10 13:54	公开评论区
交易状态:	正常	本单成交:	4			

商品购买提示:

未设置交易密码, 不能参与任何交易. [请点此进入账户中心设置](#)

商品描述

- 1, 出一100W条上海各级机关单位人员信息, 这是第一部分
第二部分也请在数据专区找, 那一份80W条左右.
- 2, 数据不全是有电话, 一半一半, 看清楚, 拍之前考虑清楚
- 3, MEGA盘自动发货, 安全保密
- 4, 虚拟物, 链接失效(可回信补链接), 概不退款, 拍前务必考虑清楚
- 5, 东西下好之后, 没问题, 请第一时间放币, 都是成年人, 请有点契约精神.

附件:

R947738	fx											
	A	B	C	D	E	F	G	H	I	J	K	L
159870	INSERT IN	'梁秀琴'	'女'	'汉族'	null	'中共上海'	3101041	null	'1361185'	null	'中等专科');	
159871	INSERT IN	'卡建国'	'男'	'汉族'	null	'中共上海'	3101021	null	null	null	'普通高中');	
159872	INSERT IN	'马小煜'	'男'	'汉族'	null	'中共上海'	3205021	null	null	'6234236'	'大学');	

暗网中个人信息买卖

主题帖交易信息一览

交易编号:	31830	商品单价:	20 [美元]	交易发布时间:	2019-08-27 19:04	加入收藏
卖家账号:	445353	单价折算:	0.00253 [比特币]	商家最后在线:	2020-03-10 10:01	公开评论区
交易状态:	正常	本单成交:	9			

商品购买提示:

未设置交易密码, 不能参与任何交易. [请点此进入账户中心设置](#)

商品描述

5000套身份证照片, 包含一张身份证正面照, 一张身份证反面照, 一张手持身份证照。

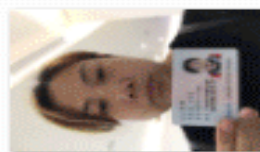
身份证大部分是8090后, 数据共5.65G。

注意: 数据具有可复制性, 一经售出, 概不退款。

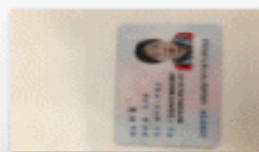
附件:



708163_5b1882
6b82766



708163_5b1882
7465da3



708163_5b1882
6158803



708183_5b1882
f30e1d4



708183_5b1883
0ef116b



708183_5b1883
1a751c7

比特币

比特币 - Bitcoin

Investing.com指数 ▼ 货币 USD ▼ · 免责声明

28,183.1 **+269.9 (+0.97%) ▲**

1D 1W 1M 6M 1Y **5Y** Max



• 2023年10月17日行情

什么是暗网

- 暗网又被称为隐藏网（Hidden Web），普通用户无法通过常规手段搜索和访问它，它是**深网**（Deep Web）的重要组成部分。
- 暗网用的软件由**美国海军**研究实验室开发出来的**匿名系统**，用于避免在网上的活动被追踪到。
- 暗网因其与生俱来的隐匿特性，现在被不法分子广泛运用于网络犯罪。

暗网汇聚了很多像诈骗、色情、毒品等违法信息。

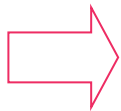


网络信息安全意识提升

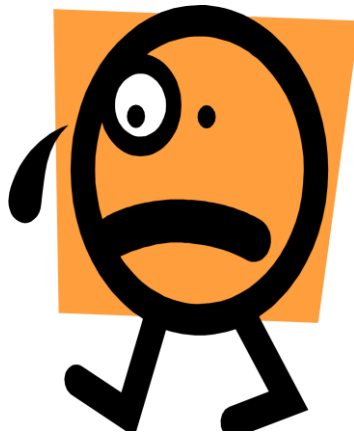
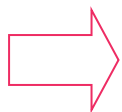
网络信息安全建设的目（工作方针）



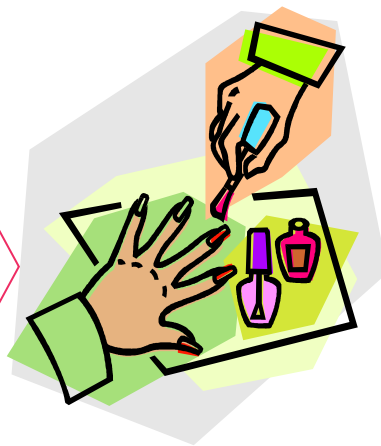
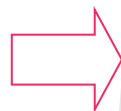
进不来



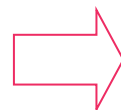
拿不走



看不懂



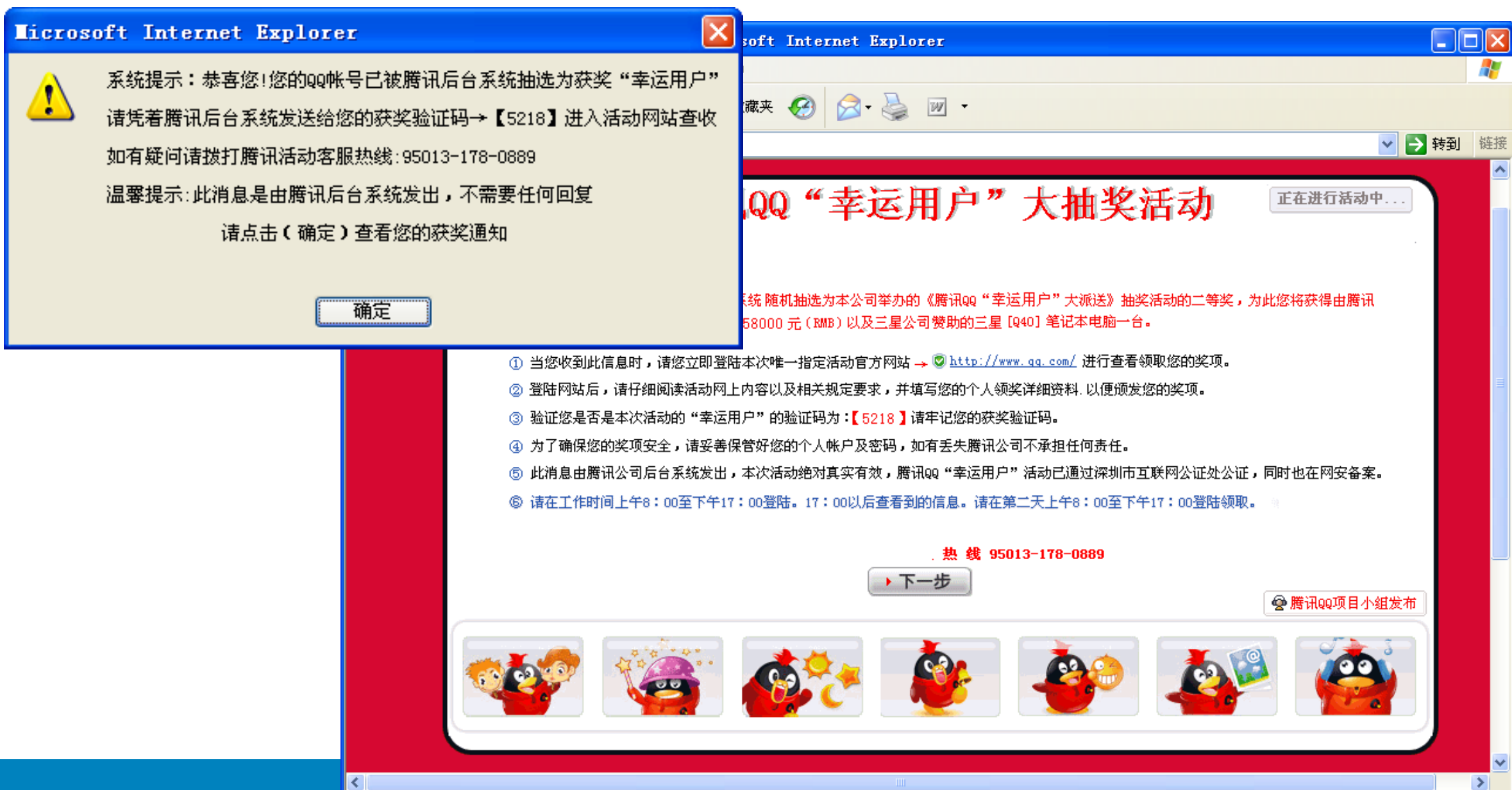
改不了



走不脱



网络钓鱼案例：



网络钓鱼案例：

QQ在线用户—大抽奖 - Microsoft Internet Explorer

文件(E) 编辑(E) 查看(V) 收藏(A) 工具(T) 帮助(H)

后退 前进 刷新 地址 搜索 收藏夹 打印 链接

地址: <http://www.txzyxx.biz/3.htm> 转到 链接

注意事项：尊敬的qq用户：现在请填写以下表格（必须真实，如因填写有误，导致奖项无法送达，本公司概不负责）
因为您的奖品是通过邮寄的方式，把您的奖品邮寄到您所填写的地址上，而您的奖金是通过网上转帐的形式转入您所填写的银行账号内，如果您要是没有银行账号，您的奖金会折成支票，连同奖品一起以邮寄的方式邮寄给您。（带*号为必填项）

奖品. 如有任何疑问, 请您咨询腾讯客服热线: 95013-178-0889

输入QQ号码: *请填写您的中奖QQ号

确认QQ号码: *

真实姓名: * 请填写您的真实姓名.

出生年月: 年 月

性别: *

职业: *

月收入水平: *

身份证号码: *

详细地址: * 领取奖品地址. 咨询

邮政编码: * 您当地的邮政编码.

获奖验证码: * 请填写您的获奖验证码.

奖金领取方式: * 请选择奖金领取方式

选择银行: * 以便公司按照指定银行把奖金快速转帐给您.

银行帐号/卡号: * 您的银行帐号/卡号.

持卡人姓名: * 银行帐号/卡号 开户人姓名.

欢迎您进入腾讯QQ在线活动官方网站，如有问题请立即拨打腾讯活动客服热线: 95013-178-0889

Internet

MS14-065浏览器漏洞与网络钓鱼

- Microsoft Internet Explorer远程内存破坏漏洞(CVE-2014-6344) (MS14-065)

- 受影响系统：
- Microsoft Internet Explorer 9
- Microsoft Internet Explorer 8



- 描述：
- Internet Explorer 8, 9版本在实现上存在远程内存破坏漏洞，远程攻击者诱使受害者查看构造的网页，利用此漏洞可执行任意代码或导致拒绝服务（内存破坏）。

微盟删库事件的思考

- 微盟,香港主板上市企业(股票代码:2013.HK), 成立于2013年, 是中国企业云端商业及营销解决方案提供商, 同时也是中国精准营销服务提供商。



关于微盟系统故障的通告

尊敬的微盟商户：

和您一样，我们一起度过了煎熬的 36 小时，我们预计此次故障还会持续一段时间，现就此次系统故障作如下通告：

2 月 23 日 19 点，我们收到系统监控报警，服务出现故障，随后我们立刻召集相关技术人员进行定位，发现大面积服务集群无法响应，生产环境及数据遭受严重破坏。我们立刻启动应急响应机制，并与腾讯云技术团队一起研究制定生产环境和数据修复方案。

微盟2020年净亏损11.7亿元：“删库”事件赔付1.2亿元 股价两连跌重挫20%



金融界

2021-03-19 20:52

北京富华创新科技发展有限公司官方帐号,优质财经领域...

关注

来源：中国网科技

中国网科技3月19日讯（记者 苏畅）3月17日晚间，SaaS服务商微盟集团（02013.HK）发布2020年财报。报告显示，公司去年实现营收20.6亿元，同比增长43.7%；净亏损11.7亿元，同比减少474.7%；经调整净利润1.1亿元，同比增长39.1%。

2020年的“删库”事件拖累微盟业绩，其赔付总额达到1.16亿元。财报发布后，微盟股价连续两日下跌，累计跌幅超20%。

微盟“删库”主角贺某被判6年有期徒刑

- 微盟一夜之间市值蒸发超10亿、300万商铺惨遭瘫痪的程序员吗？
- 不仅如此，服务器故障时间长达8天之久，最终还赔付了商家1.5个亿。



黑客组织意图窃取COVID-19相关情报

- 至少从2020年1月至2020年4月，越南黑客组织APT32（OceanLotus Group）针对我国开展持续入侵活动，试图收集COVID-19相关情报。
- APT32即海莲花，APT32都以东南亚为攻击目标，并且是近几年来针对中国大陆进行攻击活动最活跃的APT攻击组织
- 该组织主要通过鱼叉攻击和水坑攻击等方法，配合多种社会工程学手段进行渗透，向境内特定目标人群传播特种木马程序，秘密控制部分政府人员、外包商和行业专家的电脑系统，窃取系统中相关领域的机密资料。

小知识：

APT攻击，即高级可持续威胁攻击，也称为定向威胁攻击，指某组织对特定对象展开的持续有效的攻击活动。

黑客组织意图窃取COVID-19相关情报

- 该组织通过**鱼叉式网络钓鱼**的方式，发送邮件至中国紧急情况管理部以及武汉市政府。
- 目前已知的第一个实例发生在2020年1月6日，APT32向我国应急管理部发送了带有嵌入式跟踪链接的电子邮件，发件人地址为 lijianxiang1870 @ 163.com，主题是“招商引资”。而嵌入的链接包含受害者的电子邮件地址和代码。



黑客组织意图窃取COVID-19相关情报

- 水坑（Watering Hole）攻击：攻击者首先通过侦察追踪，确定特定攻击目标经常访问或信任的网站，利用网站的弱点在其中植入攻击代码，使被攻击者访问网站时终端会被植入恶意程序或者直接被盗取个人重要信息，以达到入侵目标组织的目的。



案例一：服务党政涉密机关的被境外谍报机构攻击

- N网络科技有限公司是国内一家电子邮件系统安全产品提供商，主要负责客户单位内部电子邮件系统的设计、开发和维护。因为具有涉密邮件管理系统建设资质，这家公司来自全国29个省市的1500多家客户中，有很多是党政机关等涉密单位。这些单位每天都有大量的重要信息进出，渠道就是这家公司搭建的电子邮件系统。



案例二：通过社交工具传资料 涉密地图被窃取

- 国家安全机关干警对王某的计算机进行了核查取证，发现里面除了日常办公文档，还有42份标注密级的地形图。经保密部门鉴定，42份地图全部属于**国家涉密测绘图**，其中31份为机密级，11份为秘密级。这些地图已经被隐藏的窃密木马程序全部发往境外。
- 作为政府机关的工作人员，**“涉密不上网”**是基本常识，但是肖某从档案室借出涉密的地形图后，却扫描成电子版，再通过QQ从互联网上将地图发送给王某。王某完成制图后，再通过QQ将这些图纸发送给肖某。如此往来，就使境外间谍情报机关伺机盗取国家秘密的图谋得以实现。

案例三：工作邮箱密码过于简单 被境外谍报机构破解

- Z市某局的电子邮箱密码就是办公室电话号码，漏洞恰恰出在这里。境外间谍情报机关了解到我国政府部门普遍存在多人合用一个电子邮箱，而且常将办公室电话作为邮箱密码等使用习惯，利用技术手段搜集到Z市某局电话号码和邮箱账号，**成功猜解出密码**，从而非法控制了该邮箱。



chatGPT与网络安全

- ChatGPT（全名：Chat Generative Pre-trained Transformer），美国OpenAI 研发的聊天机器人程序，于2022年11月30日发布。ChatGPT是人工智能技术驱动的自然语言处理工具，它能够通过理解和学习人类的语言来进行对话，还能根据聊天的上下文进行互动，真正像人类一样来聊天交流，甚至能完成撰写邮件、视频脚本、文案、翻译、代码，写论文 等任务。



GTP是什么

- chatGPT、autoGPT，到底是什么？G、P、T到底代表什么意思？
- “GPT”代表“Generative Pre-trained Transformer”，生成式预训练转换器，是一种基于互联网可用数据训练的文本生成深度学习模型
- 其中
 - “Generative指的是该模型可以生成新的内容
 - “Pre-trained则表示该模型可以在大型语料库中进行预训练，以便更好地理解人类语言。
 - “Transformer”则是指一种神经网络架构，它可以处理变长的序列数据，例如自然语言文本。



GPT与网络安全

- 报道：
- 一个名为《ChatGPT–Benefits of Malware》的帖子在黑客圈广为流传，帖子中展示了一个Java片段，可以用来下载盗号木马、勒索病毒、流氓软件等恶意程序。
- 甚至，一个从未涉足脚本的知名黑客USDoD，在好奇心驱使之下借助 ChatGPT生成了人生第一个可以执行加解密功能的Python脚本，该脚本稍加改造就可以变成勒索病毒。

案例

- **马斯克**直播自动驾驶「去小扎家」，45分钟仅一次人工干预
- 据《福布斯》报道，这是马斯克首次公开展示特斯拉**FSD**的最新版本（Beta 9.2），该版本于2023年7月31日发布给部分特斯拉车主。
FSD是特斯拉旗下的一项高级自动驾驶功能，它可以让车辆在城市道路上实现无人驾驶，包括识别交通信号灯、标志、行人、障碍物等，并根据实时路况做出相应的转向、加速、刹车等操作。FSD目前仍处于测试阶段，尚未获得监管部门的批准，因此车主仍需保持注意力并随时准备接管车辆。



AI人工智能还会帮助黑客窃取用户身份信息？

你的手机和电脑都设置密码了吗？设置密码你的隐私信息就安全了吗？不一定！



近日，研究人员警告说，如果盗窃者开始使用人工智能辅助的热成像技术来确定输入后不久的密码，目前基于密码的安全保护设施情况可能会恶化。格拉斯哥大学的研究人员公布了一种方法，通过对用户手指的热信号进行成像，来猜测键盘和手机屏幕上最近输入的密码，精确度很高。



案例：

你家的丰田RAV4很可能会被黑客攻击，海外已有车破防

2023-04-11 11:06:20 主试角的角师傅

你有没有想到，假如有一天你的车被黑客袭击了，你会害怕吗？这不是游戏《看门狗》里的技能展示，而是真正发生在身边的案例。近日，有外媒报道称EDAG Group的汽车网络安全专家Ian Tabor的自家丰田RAV4(配置|询价)就被黑客袭击了。



案例：

Pwn2Own 黑客两次攻破特斯拉，赢得 35 万美元和一辆 Model 3

2023年03月26日 14:53 IT之家



IT之家 3 月 26 日消息，3 月 23 日，全世界最著名、奖金最丰厚的黑客大赛 Pwn2Own 2023 开幕，特斯拉在该大赛上被黑客两次攻破，黑客也因此赢得了 35 万美元和一辆 Model 3 汽车。



- 海尔回应造车传闻：不造整车，入汽车市场
- 追踪月经周期外，三星Galaxy V 器还有新功能
- 三星新专利获批：一台手机四种场景需求

今日推荐

优秀作者

没有新冠疫情了，连花清瘟销售

王健林能否渡得了这一劫？

华商韬略

讲武德的马保国，请我吃了一碗

中国小报

“木马”一词的由来

- 木马(Trojan Horse), 是从希腊神话里面的“特洛伊木马”得名的
- 希腊人在一只假装人祭礼的巨大木马中藏匿了许多希腊士兵并引诱特洛伊人将它运进城内, 等到夜里马腹内士兵与城外士兵里应外合, 一举攻破了特洛伊城。

中文名	特洛伊
外文名	Troy
类 型	动作, 冒险, 爱情, 剧情
出品公司	华纳兄弟影片公司
制片地区	美国
出品时间	2004年
制片成本	1.75亿美元



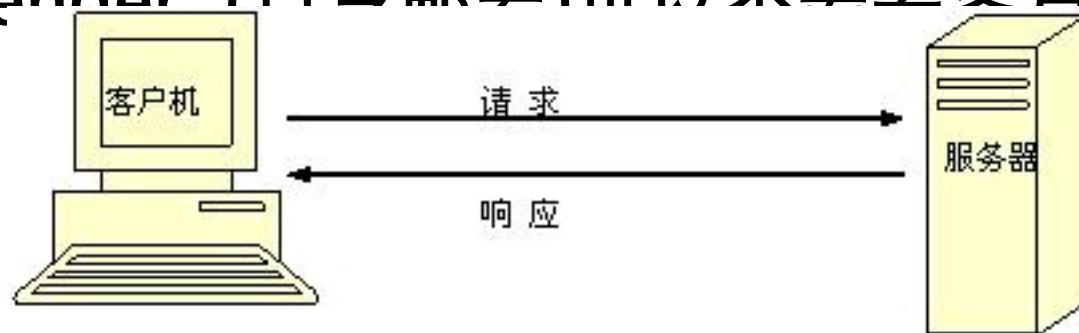
特洛伊木马

- **特洛伊木马**是指黑客用来远程控制目标计算机的特殊程序。凡是非法驻留在目标计算机里，并执行预定的操作，窃取目标的私有信息，都属于特洛伊木马。

- **工作方式：C/S模式**

服务器端安装在目标机里，监听等待攻击者发出的指令；客户端是用来控制目标机器的部分，放在攻击者机器上。

木马“Passwd Sender”(口令发送)可以不安装客户端。



特洛伊木马

- 木马的伪装

- 冒充图象文件或游戏程序
- 捆绑程序欺骗

将木马程序与正常文件捆绑为一个程序

- 伪装成应用程序扩展组件

木马名字为dll或ocx类型文件，挂在一个有名的软件中。

后两种方式的欺骗性更大。

特洛伊木马

- 木马的特点
 - **隐蔽性强** 早期的木马按“Ctrl + Alt + Del”能显露出来,但现在大多数木马只能采用内存工具来看内存中是否存在木马。
 - **潜伏能力强** 表面上的木马被发现并删除以后,后备的木马在一定的条件下会跳出来。
 - **非授权性** 一旦控制端和服务端连接后, 控制端将享有服务端的绝大部分操作权限, 包括窃取口令、拷贝或删除文件、修改注册表、控制鼠标、键盘、重新启动计算机等。

特洛伊木马

- 如何对付木马

- 1) 端口扫描

- 2) 查看连接: netstat -a 命令

上述两种方法对驱动程序/动态链接木马无效。

- 3) 检查注册表

- 4) 查找木马文件: 如kernel32.exe,
sysexplr.exe等

- 5) 文件完整性检查:

开始→程序→附件→系统工具→系统信息→工具 →系统文件
检查器。

如有损坏可从安装盘还原。

什么是系统漏洞

- 漏洞即某个程序(包括操作系统)在设计时未考虑周全，当程序遇到一个看似合理，但实际无法处理的问题时，引发的不可预见的错误。系统漏洞又称安全缺陷，对用户造成的不良后果如下所述：
- 如漏洞被恶意用户利用，会造成信息泄漏，如黑客攻击网站即利用网络服务器操作系统的漏洞。
- 对用户操作造成不便，如不明原因的死机和丢失文件等。
- 综上所述，仅有堵住系统漏洞，用户才会有一个安全和稳定的工作环境。

CVE-2017-11882 漏洞

- 一个隐藏17年之久的漏洞
- 通杀所有版本的漏洞。该漏洞的成因是EQNEDT32.EXE进程在读入包含MathType的ole数据时，在拷贝公式字体名称时没有对名称长度进行校验，从而造成栈缓冲区溢出，是一个非常经典的栈溢出漏洞。
- 影响版本：
 - office 2003
 - office 2007
 - office 2010
 - office 2013
 - office 2016



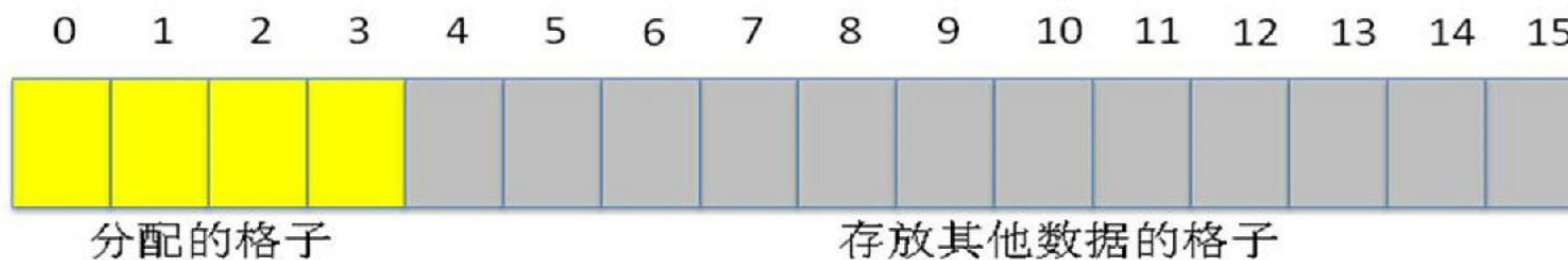
为什么会有漏洞

- 编程人员的**人为因素**，在程序编写过程，为实现不可告人的目的，在程序代码的隐蔽处保留后门。
- 受编程人员的能力、经验和当时安全技术所限，在程序中难免会有不足之处，轻则影响程序效率，重则导致非授权用户的权限提升。
- 由于硬件原因，使编程人员无法弥补硬件的漏洞，从而使硬件的问题通过软件表现。

缓冲区溢出

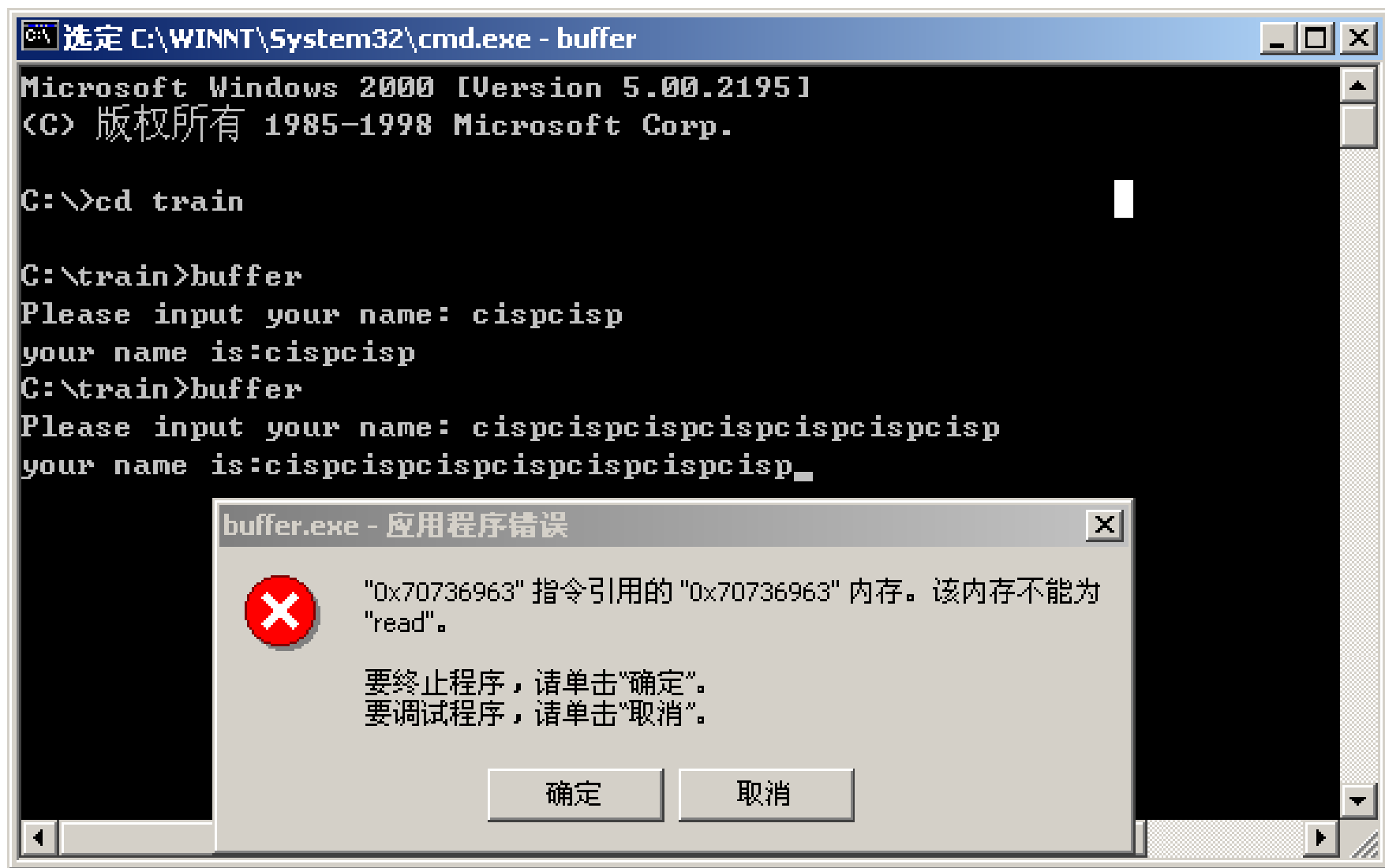
- 缓冲区(buffer): 用于临时存储数据的一段内存区域
- 溢出(overflow): 数据过长导致无法存储在预期区域内

缓冲区接收数据之前的情况



缓冲区溢出时的情况





虚拟键盘

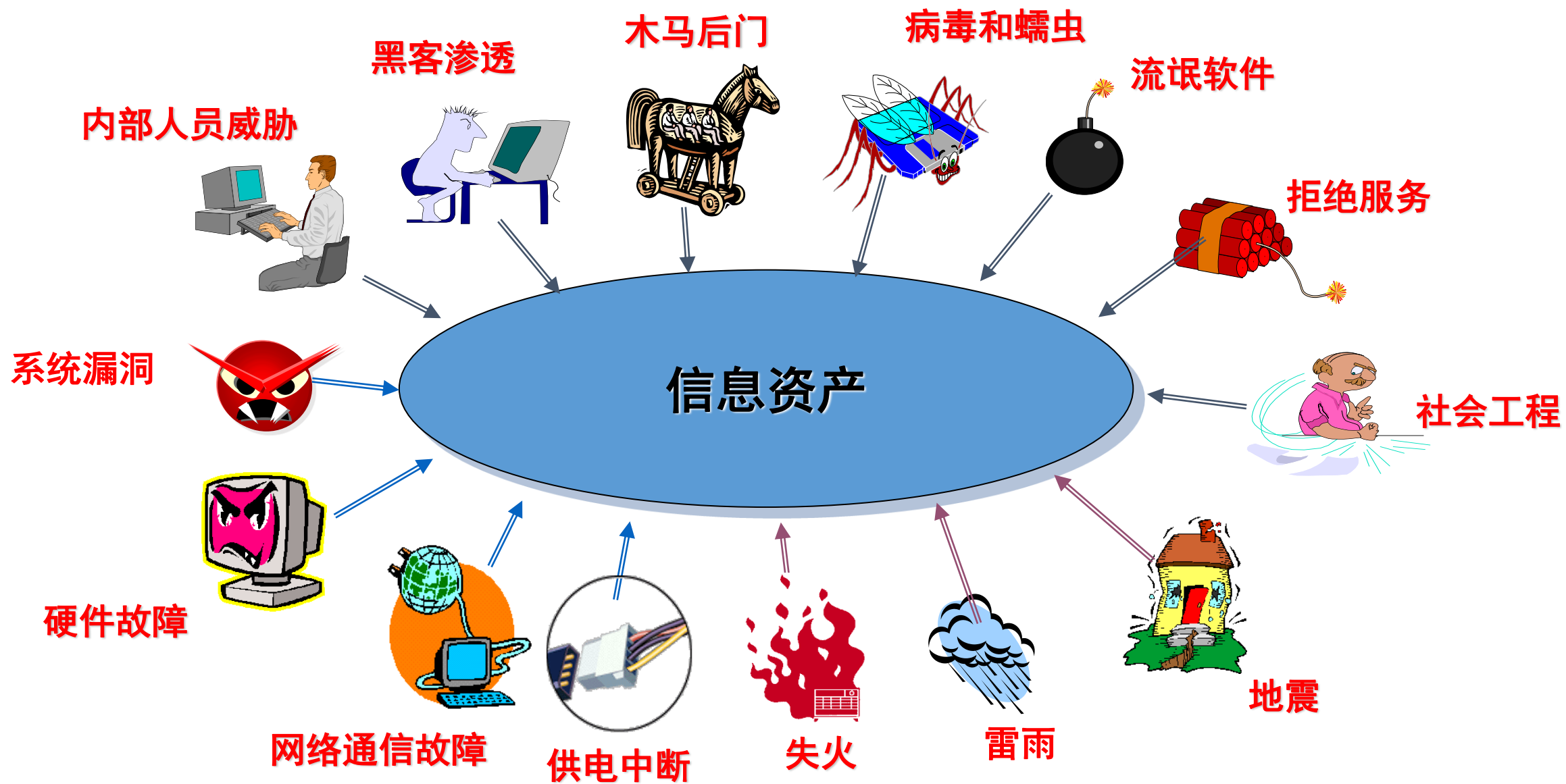


木马的识别与清除

kkpebhf dupoui j						
进程	驱动模块	内核	内核钩子	应用层钩子	网络	注册表
映像名称	进程ID	父进程ID	映像路径	EPROCESS	应用层访问...	文件厂商
System	4	-	System	0x8AF94490	拒绝	
smss.exe	692	4	C:\WINDOWS\system32\smss.exe	0x88CD0D78	拒绝	Microsoft
winlogon.exe	788	692	C:\WINDOWS\system32\winlogon.exe	0x88CC3988	拒绝	Microsoft
lsass.exe	844	788	C:\WINDOWS\system32\lsass.exe	0x87B8ADA0	拒绝	Microsoft
services.exe	832	788	C:\WINDOWS\system32\services.exe	0x88D3DCA0	拒绝	Microsoft
alg.exe	2164	832	C:\WINDOWS\system32\alg.exe	0x8799FDA0	拒绝	Microsoft
HD-Service.exe	2016	832	C:\Program Files\BlueStacks\HD-Service.exe	0x87AA7980	拒绝	BlueStack
HD-SharedFolder.exe	564	2016	C:\Program Files\BlueStacks\HD-SharedFolde...	0x87A58B30	拒绝	BlueStack
HD-BlockDevice.exe	436	2016	C:\Program Files\BlueStacks\HD-BlockDevice...	0x87A7DB30	拒绝	BlueStack
HD-Network.exe	296	2016	C:\Program Files\BlueStacks\HD-Network.exe	0x87A75DA0	拒绝	BlueStack
wdfmgr.exe	1956	832	C:\WINDOWS\system32\wdfmgr.exe	0x889F9878	拒绝	Microsoft
svchost.exe	1748	832	C:\WINDOWS\system32\svchost.exe	0x8798AB30	拒绝	Microsoft
HD-LogRotatorService...	1660	832	C:\Program Files\BlueStacks\HD-LogRotatorS...	0x87AE38C0	拒绝	BlueStack
spoolsv.exe	1580	832	C:\WINDOWS\system32\spoolsv.exe	0x87AF3DA0	拒绝	Microsoft
ZhuDongFangYu.exe	1284	832	C:\Program Files\360\360Safe\deepscan\Zhu...	0x87B58B30	拒绝	360.cn
svchost.exe	1264	832	C:\WINDOWS\system32\svchost.exe	0x87B2ADA0	拒绝	Microsoft
svchost.exe	1236	832	C:\WINDOWS\system32\svchost.exe	0x87B28DA0	拒绝	Microsoft
svchost.exe	1136	832	C:\WINDOWS\system32\svchost.exe	0x87B46B30	拒绝	Microsoft
svchost.exe	1096	832	C:\WINDOWS\system32\svchost.exe	0x87B5AB30	拒绝	Microsoft
svchost.exe	1052	832	C:\WINDOWS\system32\svchost.exe	0x87B558C0	拒绝	Microsoft
TXPlatform.exe	2084	1052	D:\Program Files\Tencent\QQ\Bin\TXPlatform...	0x87493020	-	Tencent
DFServ.exe	1020	832	C:\Program Files\Farionics\Deep Freeze\Insta...	0x87B63DA0	拒绝	Faronics (
FrzState2k.exe	1648	1020	C:\Program Files\Farionics\Deep Freeze\Insta...	0x8870EDA0	-	Faronics (
csrss.exe	764	692	C:\WINDOWS\system32\csrss.exe	0x88CCBA78	拒绝	Microsoft
explorer.exe	1964	1756	C:\WINDOWS\explorer.exe	0x87A9DDA0	-	Microsoft

PCHunter

安全威胁



信息安全工作

《2023上半年云安全态势报告》（腾讯）

- 边界安全防护依然是网络安全防护的重点。根据报告显示，公有云在面临攻击的时候，几乎96.1%的攻击来源于外网，而3.9%的攻击来自于内网横移和跨网段攻击等其他来源。这意味着大多数的攻击基本上都来自于外网，所以边界安全防护依然是企业们最重点的防护关注点。

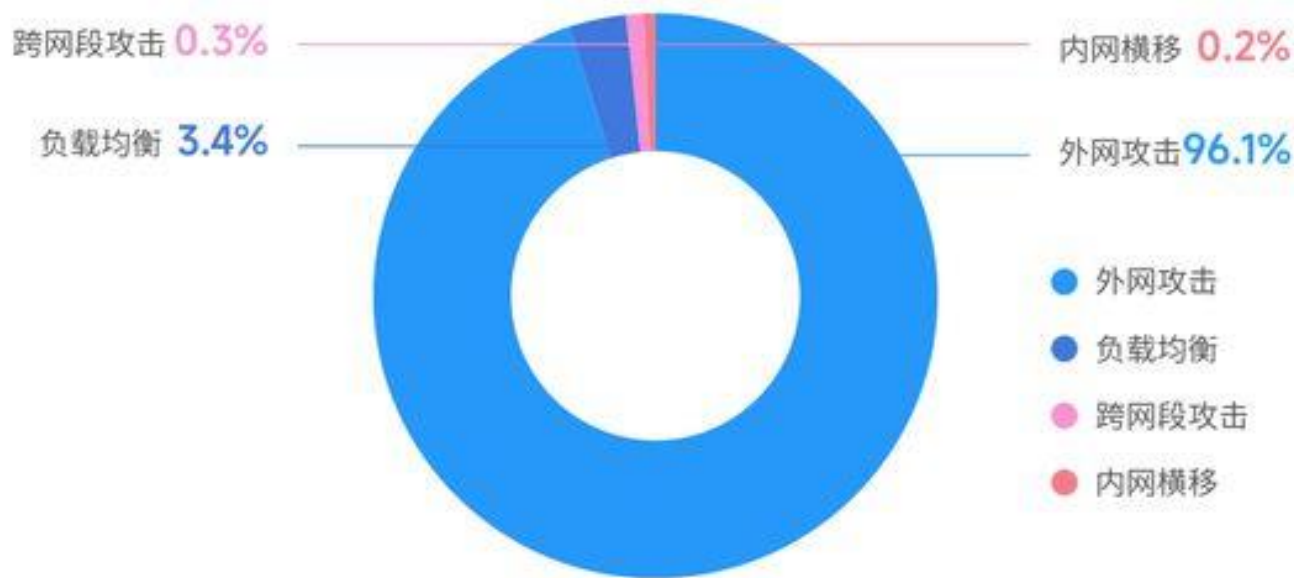


图3:2023上半年云上被攻击次数来源占比图

《2023上半年云安全态势报告》（腾讯）

- 2023年上半年各类攻击次数统计



网络与信息安全责任考核

- 一是提高政治站位，切实把思想和行动统一到习近平总书记对网络安全工作重要批示指示和党的二十大精神上来，深刻认识网络安全面临的形式和挑战。
- 二是全面落实网络与信息安全各项责任，以时时放心不下的责任感，严格落实网络安全责任制各项部署，准确把握发展规律，加大人、财、物的支撑保障力度，主动扛起筑牢网络安全屏障的国企责任担当。
- 三是着力落实习近平总书记关于打击治理电信网络诈骗犯罪工作重要指示精神，电信网络诈骗案件和损失金额实现“双降”的基础上，持续加大防范治理力度，守护好群众“钱袋子”。
- 四是积极构建可靠有效的网络安全保障体系，加强关键基础设施防护，持续增强5G、工业互联网、车联网等新型融合领域安全保障能力，做好数据安全分级分类管理，持续保护重要资源和用户个人信息不受侵犯。

实名制

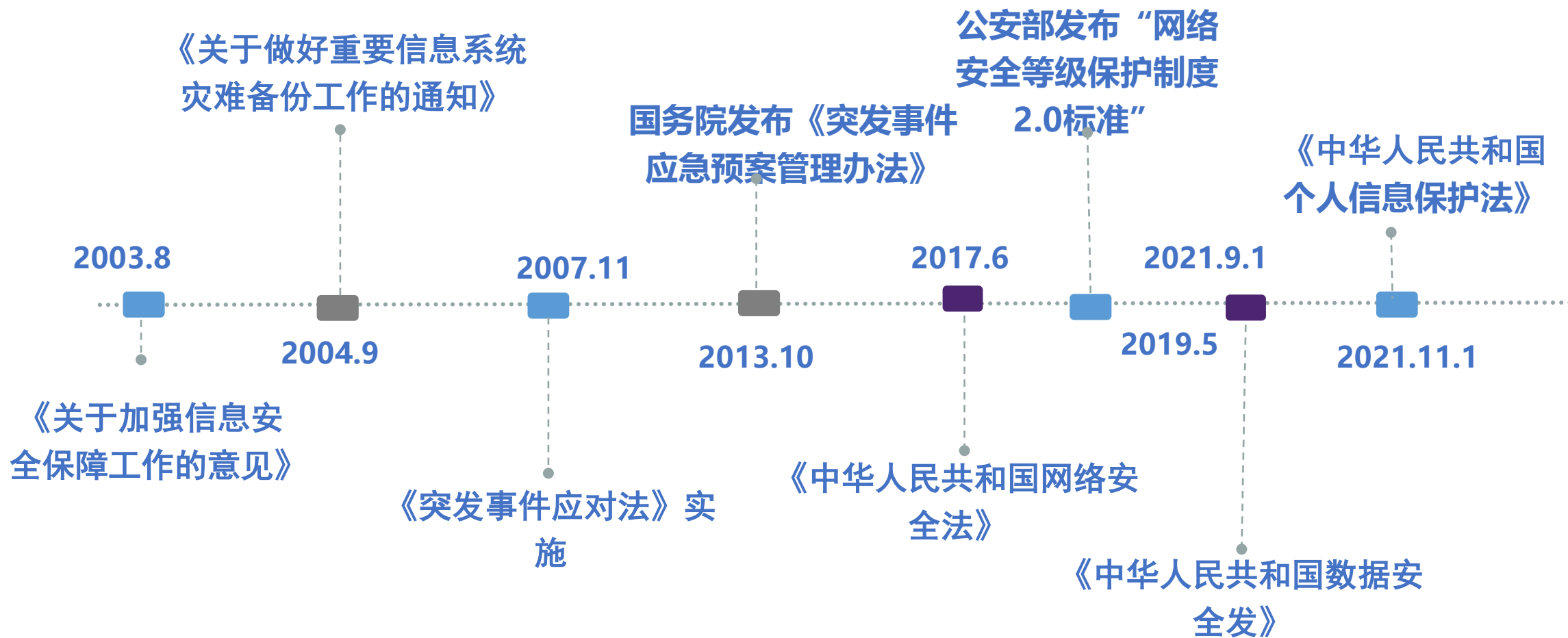
- 网络安全法网络实名制的规定
- 【第24条】 网络运营者为办理网络接入、域名注册服务，办理固定电话、移动电话等入网手续，或者为用户提供信息发布、即时通讯等服务，在与用户签订协议或者确认提供服务时，应当**要求用户提供真实身份信息**。用户不提供真实身份信息的，网络运营者不得为其提供相关服务。国家实施网络可信身份战略，支持研究开发安全、方便的电子身份认证技术，推动不同电子身份认证之间的互认。
 - 解读：本条规定了网络运营者必须履行的核心义务之一就是实名制。本条在电信用户实名制基础上，规定了信息发布、即时通讯等服务的实名制要求，实名制将不再仅限于通讯领域，微信、QQ、论坛、贴吧以及网站新闻跟贴等具备信息发布和即时通讯等服务的网络产品应用都须进行用户身份实名制。对于没有落实好实名制的网络运营者将面临高额处罚甚至被勒令停业。

实名制

- 《网络安全法》第六章 第六十一条规定：
- 网络运营者未要求用户提供真实身份信息，或者对不提供真实身份信息的用户提供相关服务的，由有关主管部门责令改正；拒不改正或者情节严重的，处五万元以上五十万元以下罚款，并可以由有关主管部门责令暂停相关业务、停业整顿、关闭网站、吊销相关业务许可证或者吊销营业执照，对直接负责的主管人员和其他直接责任人员处一万元以上十万元以下罚款。

法律法规与案例解析

重要法律法规实施



《网络安全法》违法案例

- 攀枝花市某有限责任公司未履行网络安全保护义务案
- 该公司委托外地一家互联网公司开发了一个名叫“攀枝花水果商城”的电子商务网站。检查发现，该公司网站的标题**被篡改**为“哪里能开成都专用发票”，并留有明确的联系QQ和电话号码，显然已成为网络“黑灰产”犯罪分子用来非法引流的网络肉机。
- 该公司由于没有建立网络安全管理制度，没有履行网络安全保护义务，直接导致该公司网站被篡改。未履行网络安全保护义务的行为违反了《网络安全法》第二十一条之规定，攀枝花市公安局……



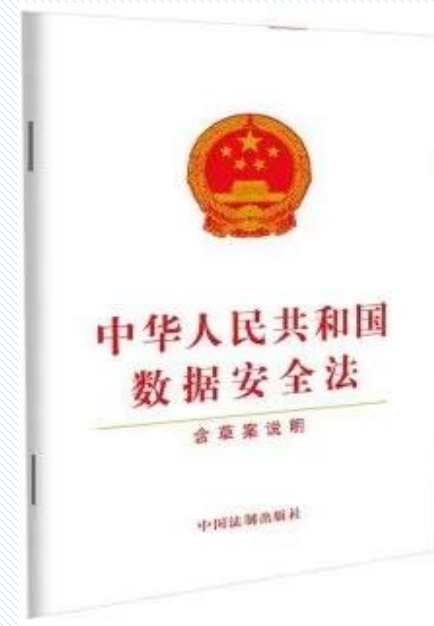
《网络安全法》违法案例

- 重庆一网络公司未留存用户登录日志被网安查处
- 重庆公安局网安总队在日常检查中发现，重庆市某科技发展有限公司自《网络安全法》正式实施以来，在提供互联网数据中心服务时，存在未依法留存用户登录相关网络日志的违法行为。公安机关根据《网络安全法》相关规定，决定给予该公司警告处罚，并责令限期15日内进行整改。
- 执法机构：重庆公安局网安总队

《网络安全法》第二十一条（三）项规定：采取监测、记录网络运行状态、网络安全事件的技术措施，并按照规定留存相关的网络日志**不少于六个月**。

《数据安全法》

- 2021年9月1日，《中华人民共和国数据安全法》。该部法律体现了总体国家安全观的立法目标，聚焦**数据安全领域**的突出问题，确立了数据分类分级管理，建立了数据安全风险评估、监测预警、应急处置，数据安全审查等基本制度，并明确了相关主体的数据安全保护义务，这是我国首部数据安全领域的基础性立法。



《数据安全法》



(一) 总则的要点

- 1) 适用范围：在中国境内开展数据活动的组织和**个人**。
- 2) 定义：定义数据是指任何以电子或者非电子形式对信息的记录。
- 3) 保护要求：采取必要措施，对数据进行有效保护和合法利用，并持续保持其安全能力。
- 4) 责任任务：工业、**电信**、交通、金融、自然资源、卫生健康、教育、科技等主要行业会落地数据保护行业规范，并且落地本部门的数据安全规范。公安机关、国家安全机关等在各自职责范围内承担数据安全监管职责。网信部门负责统筹协调和监管。
- 5) 特别的对行业组织提出了制定安全行为规范，加强行业自律，指导会员加强数据安全保护的要求。这项法规有效的消灭了灰色地带，对各行业都形成了法律约束，杜绝了数据的随意共享和流转。

(二) 数据安全与发展要点

- 1) 发展原则：国家统筹发展和安全，坚持保障数据安全与促进数据开发利用并重。
- 2) 战略要求：省级以上人民政府应制定数字经济发展规划。进一步细化了国家数据战略的执行主体。
- 3) 标准体系：国家主管部门负责相关标准和体系的制定。
- 4) 评估认证：国家促进数据安全检测评估、认证等服务的发展，支持专业机构依法开展服务。
- 5) 人才培养：要采取多种方式培养数据开发利用技术和数据安全专业人才。

(三) 数据安全制度要点

- 1) 分类分级：国家建立数据分类分级保护制度，对数据实行分类分级保护，并确定重要数据目录，加强对重要数据的保护。
- 2) 风险评估：要建立集中统一、高效权威的数据安全风险评估、报告、信息共享、监测预警机制。
- 3) 应急处置：要建立数据安全应急处置机制。
- 4) 安全审查：要建立数据安全审查制度。
- 5) 出口管制：对属于管制物项的数据依法实施出口管制，可以根据实际情况对该国家或者地区对等采取措施。这项法规进一步明确了国家对中国数据的主权，即我国数据是否在境内，依然受到中国法律的保护。

（四）数据安全保护义务要点

- 1) 管理制度:在网络安全等级保护制度的基础上，建立健全全流程数据安全管理制度，组织开展**教育培训**。重要数据的处理者应当明确数据安全负责人和管理机构，进一步落实数据安全保护责任主体。
- 2) 风险监测：对出现缺陷、漏洞等风险，要**采取补救措施**；发生数据安全事件，应当立即采取处置措施，并按规定上报。
- 3) 风险评估：定期开展风险评估并上报风评报告。
- 4) 数据收集：任何组织、个人收集数据必须采取**合法、正当**的方式，不得窃取或者以其他非法方式获取数据。
- 5) 数据交易：数据服务商或交易机构，要提供并**说明数据来源证据**，要审核相关人员身份并留存记录。

(五) 政务数据安全性与开放要点

- 1) 管理制度:建立健全全流程数据安全管理制度, 落实数据安全保护责任。
- 2) 存储加工: 委托他人存储、加工或提供政务数据, 应当经过**严格审批**, 并做好监督。受托方不得擅自留存、使用、泄露或向他人提供政务数据。
- 3) 数据开放: 构建统一政务数据开放平台, 发布数据开放目录, 推动政务数据开放利用。
- 4) 适用主体: 法律、法规授权的具有管理公共事务职能的组织。



深驾

56
文章

45万
总阅读

[查看TA的文章>](#)

评论



0

重磅！滴滴事件的2个月后，数据安全法将正式实施

2021-07-29 11:16

目前在国内，关于数据方面的法律主要依托《中华人民共和国网络安全法》（2017年实施）、《中华人民共和国数据安全法》（2021年实施）。《网络安全法》主要是针对网络安全建设的指导，而新出台的《数据安全法》，则是更加明确了数据安全底线规范。

滴滴事件，体现了国家整治违法收集数据、维护数据主动权的决心。随着数据在社会资源流通中扮演的角色越来越重要，如何合法收集和使用数据也成了每一个互联网公司必须要重视的问题，可以说是公司的生命线。任何胆敢逾越数据安全红线的公司，必将得到严惩！

存在8方面16项违法事实 滴滴被罚80.26亿元

发稿时间： 2022-07-25 10:38 来源：人民邮电报 作者：语沐

A A | 分享

根据网络安全审查结论及发现的问题和线索，国家互联网信息办公室依法对滴滴全球股份有限公司涉嫌违法行为进行立案调查。经查实，滴滴全球股份有限公司违反《网络安全法》《数据安全法》《个人信息保护法》的违法违规行为事实清楚、证据确凿、情节严重、性质恶劣。

7月21日，国家互联网信息办公室依据《网络安全法》《数据安全法》《个人信息保护法》《行政处罚法》等法律法规，对滴滴全球股份有限公司处人民币80.26亿元罚款，对滴滴全球股份有限公司董事长兼CEO程维、总裁柳青各处人民币100万元罚款。

案例：

「案例警示」全省首起~公司违反《数据安全法》被行政处罚！

播报文章



山东网警巡查执法

2022-05-27 04:30

山东省公安厅网络安全保卫总队

关注

近期，枣庄网警在执法检查中发现，某公司自建收费系统，通过公众号采集公民个人信息，存储在第三方云平台上，但对采集的数据未采取安全防护技术措施，未依法履行网络安全保护义务。

枣庄市台儿庄网警根据《中华人民共和国数据安全法》第27条第一款、第45条第一款之规定，对该公司予以行政警告处罚，并责令改正。

法律链接

- 《中华人民共和国数据安全法》第二十七条：开展数据处理活动应当依照法律、法规的规定，建立健全全流程数据安全管理制度，组织开展数据安全教育培训，**采取相应的技术措施和其他必要措施，保障数据安全**。利用互联网等信息网络开展数据处理活动，应当在网络安全等级保护制度的基础上，履行上述数据安全保护义务。
- 重要数据的处理者应当明确数据安全负责人和管理机构，落实数据安全保护责任。

首例适用《数据安全法》！某公司未履行数据安全保护义务被立案处罚

等级保护测评 发布于 2022-07-27 06:16:05 阅读 6394

7月26日，广州市公安局新闻办公室召开新闻发布会，通报2022年广州民生实事“个人信息超范围采集整治治理”专项工作和“净网2022”专项行动中，全链条打击侵犯公民个人信息等突出网络违法犯罪的相关情况和典型案例。其中，公布了广东省公安机关首例适用《中华人民共和国数据安全法》的案件——某技术公司在开发一款App系统后，因未履行数据安全保护义务，导致该系统安全漏洞被不法分子利用，1000余万条公民个人信息面临泄露风险，被警方行政立案，罚款5万元。

如何保护数据

数据安全、访问控制和数据保护听起来可能类似，但有一些区别需要注意



数据安全

你是你说的那个人吗



访问控制

证明你是你说的那个人



数据保护

如何确保数据已经被保护

数据安全的六大基础

数据安全的六大基础

01

意识到信息安全不仅仅是首席信息官的工作。

02

将数据和信息视为业务资产般保护。

03

保护可移动媒体和移动设备上的重要数据。

04

知道您组织的重要数字资产的位置。

05

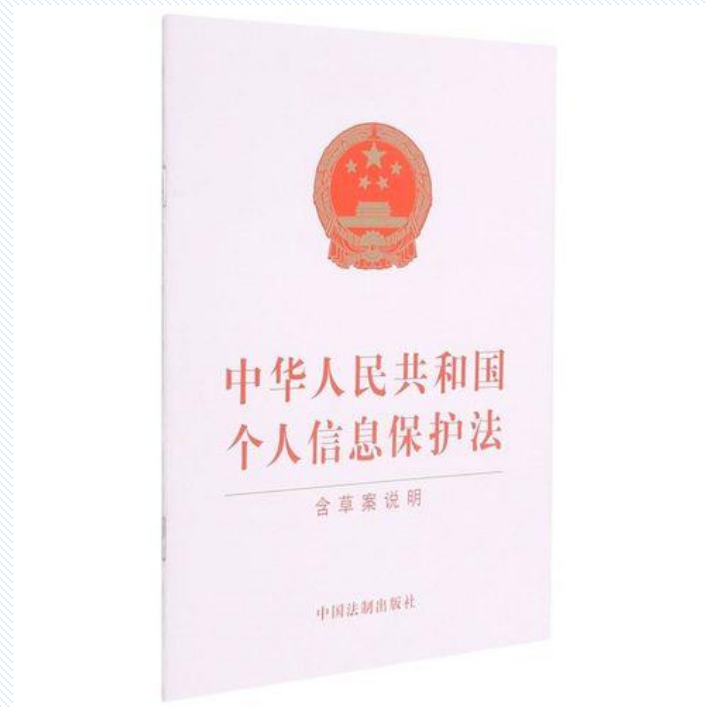
意识到并非所有数据泄露都是由于外部攻击而发生的。员工也可能有意或无意地导致数据泄露。

06

认识到满足立法和法规标准只是信息安全战略的起点。

《个人信息保护法》

- **2021年11月1日**,我国首部专门针对个人信息保护的综合性法律——《中华人民共和国个人信息保护法》正式实施。



《个人信息保护法》

全文涵盖了八章，七十四条内容。

- 第一章 总则（12条）
- 第二章 个人信息处理规则（25条）
- 第三章 个人信息跨境提供的规则（6条）
- 第四章 个人在个人信息处理活动中的权利（7条）
- 第五章 个人信息处理者的义务（9条）
- 第六章 履行个人信息保护职责的部门（6条）
- 第七章 法律责任（6条）
- 第八章 附则（3条）

《个人信息保护法》解读

一、“规范个人信息处理活动”是个人信息保护法的核心

- 立法目的不仅仅是“**保护**”个人信息，而是“保护”和“**利用**”同步推进。
- “规范个人信息处理活动”处于整个《个人信息保护法》的核心地位，只有夯实“规范个人信息处理活动”这个关键环节，才能确保实现保护个人信息权益和促进个人信息合理利用之目的。

《个人信息保护法》解读

二、个人信息的内涵与匿名化核心

- “个人信息”的定义：“个人信息是以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。
- “匿名化”定义为：“是指个人信息经过处理无法识别特定自然人且不能复原的过程。”该定义中的“不能复原”主采取了两种方法：
 - 一是删除个人信息包含的个人描述部分，包括将描述部分替换为其他描述部分，或者使用具有不可恢复的方法等；
 - 二是删除所述个人信息中所包含的全部标识符，包括将标识符替换为其他描述部分，或者使用具有不可恢复的方法等。

《个人信息保护法》解读

三、个人信息保护法的域外效力

- 一是“以向境内自然人提供产品或者服务为目的”，比如一家位于美国运营的电子商务网站（Amazon）向中国境内的自然人（包括本国人、外国人和无国籍人）提供产品或服务；
- 二是“分析、评估境内自然人的行为”，比如一家位于境外的社交网站分析、评估中国境内自然人的行为，像全球最大的社交网站 Facebook，每年发布专门的用户行为习惯研究分析报告；
- 三是法律、行政法规规定的其他情形。

《个人信息保护法》解读

四、个人信息处理的核心原则

- 总则部分第六条确立的两个“**最小原则**”，是个人信息处理应遵循的核心原则，尤其是处理目的的“**最小范围**”，这是禁止“过度收集个人信息”的关键要点，因为个人信息处理者只有在严格遵守处理目的的“**最小范围**”的前提下，即“**非必要不收集**”的情况下，才能确保其采取对个人权益影响最小的方式。

《个人信息保护法》解读

五、敏感个人信息的认定与保护规则

- 第二十八条给出了“敏感个人信息”的定义，即“敏感个人信息是一旦泄露或者非法使用，容易导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息，包括生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等信息。
- 将不满十四周岁未成年人的个人信息也纳入了“敏感个人信息”给予重点保护。

《个人信息保护法》解读

七、严禁“大数据杀熟”以及为“用户画像”等涉及不当自动化决策

- 《个人信息保护法》就个人信息处理者利用个人信息进行自动化决策重点确立了一项义务性规范和一项禁止性规定：
- 一是应当保证决策的透明度和结果公平、公正；
- 二是不得对个人在交易价格等交易条件上实行不合理的差别待遇。

个保法行政处罚案例（1）

- 江苏苏州相城网安部门在对苏州某科技有限公司检查时发现，该公司开发运营的某小程序在收集用户申请基因检测个人信息时，**未向**被收集者明示处理个人信息的方式、种类及保存期限等，在存储、传输个人基因检测报告等敏感信息时未采取必要的安全技术措施，涉嫌处理个人信息未告知并征得个人同意和不履行个人信息安全保护义务。
- 网安部门依据《中华人民共和国个人信息保护法》第13条、第17条、第51条和第66条规定，对该公司予以行政警告处罚并责令限期改正。

个保法行政处罚案例（2）

- 网安部门在对句容市宝华镇某售楼处检查时发现，自2020年2月以来，该售楼处为统计、结算中介业务提成给付比例，在未告知并征得购房者同意的情况下，在售楼处安装十余台高清人脸抓拍摄像头，抓取相关购房者人脸照片并与售楼处内部人员业务数据库进行比对，涉嫌在公共场所超范围采集购房者个人信息。
- 网安部门根据《中华人民共和国个人信息保护法》第26条和第66条规定，对该公司予以行政警告处罚并责令限期改正。

个保法行政处罚案例（3）

- 网安部门在对常州某网络科技有限公司日常检查时，发现该公司运营一款为在校学生提供外卖配送及快递代取服务APP，采集储存大量会员姓名、手机号码等个人信息，但该APP对采集的公民个人信息未采取相应的加密、去标识化等安全技术措施，且没有制定内部管理制度和操作规程，涉嫌不履行个人信息安全保护义务。
- 网安部门依据《中华人民共和国个人信息保护法》第51条和第66条规定，对该公司予以行政警告处罚并责令限期改正。

数据安全

DIKW模型

- DIKW模型是一种学习方法、是一种汇报逻辑、也是看待和阐述世界的不同角度。
 - D : data, 数据。
 - I : information, 信息。
 - K : knowledge, 知识。
 - W : wisdom, 智慧。
- 模型的历史可以追溯于托马斯·斯特尔那斯·艾略特所写的诗《岩石》(The Rock)。在首段,他写道:知识中的智慧我们在哪里丢失?资讯中的知识我们在哪里丢失?"(Where is the wisdom we have lost in knowledge?/Where is the knowledge we have lost in information?)
- 作者提出智慧、知识、信息的关系。智慧源于知识, 知识源于信息, 但是知识和智慧相比, 缺失了很多内容; 信息和知识相比, 也缺失很多。

DIKW模型

- DIKW模型将数据、信息、知识、智慧纳入到一种金字塔形的层次体系，每一层比下一层都赋予的一些特质。原始观察及量度获得了数据、分析数据间的关系获得了信息。在行动上应用信息产生了知识。智慧关心未来，它含有暗示及滞后影响的意味。



DIKW模型

- 数据转化为信息

- 数据的存在形式可以多种多样，比如电子表格，但DIKW模型中的数据仅仅代表数据本身，并不包含任何潜在的意义。通过某种方式组织和处理数据，**分析数据间的关系**，数据就有了意义，这就是信息（Information）。

- 数据转化为知识

- 如果说数据是一个事实的集合，从中可以得出关于事实的结论。那么知识（Knowledge）就是**信息的集合**，它使信息变得有用。知识是对信息的应用，是一个对信息判断和确认的过程，这个过程结合了经验、上下文、诠释和反省。知识可以回答“如何？”的问题，可以帮助我们建模和仿真。

- 数据转化为智慧

- 智慧可以简单的归纳为做正确判断和决定的能力，包括对知识的最佳使用。随着数据向信息、知识和智慧的发展，理解的深度在不断增加，需要考虑的范围也在扩大。

数据要素与数字经济

- 充分发挥数据要素作用 赋能数字经济发展
- 国务院印发《“十四五”数字经济发展规划》（国发〔2021〕29号，以下简称《规划》），对数据要素作出专章部署，提出强化高质量数据要素供给、加快数据要素市场化流通、创新数据要素开发利用机制等重点任务举措，对于加快形成数据要素市场体系、促进数字经济高质量发展具有重要意义。
 - 一、打通供给壁垒，强化高质量数据要素供给
 - 二、培育要素市场，加快数据要素流通交易
 - 三、挖掘应用场景，创新数据要素开发利用机制

打通供给壁垒，强化高质量数据要素供给

- 当前，我国数据供给的动力机制尚不完善，数据流通活力不足。以公共数据为例，政务服务、教育、医疗、交通、能源等领域还存在大量**沉睡数据**，如能充分开发利用，对于支撑促进经济社会发展具有重要意义，并可进一步带动更大范围的数据流通。此外，我国在数据采集加工等相关方面的制度、规范、标准等尚不成熟，从事数据清洗、分析和挖掘机构的**专业能力**有待提升，数据服务水平难以满足产业发展实际需求。
- 鉴此，《规划》提出了2方面要求。一是要培育壮大数据服务产业。支持市场主体依法合规开展数据采集，聚焦数据标注、清洗、脱敏、脱密、聚合、分析等环节，提升数据资源处理能力；培育数据服务商等社会化数据服务机构发展，依法依规开展数据的采集、整理、聚合、分析等加工业务。二是要统一标准。推动数据资源标准体系建设，提升数据管理水平和数据质量，探索面向业务应用的共享、交换、协作和开放；加快推动各领域通信协议兼容统一，打破技术和协议壁垒，加强互通互操作，形成完整贯通的数据链。

培育要素市场，加快数据要素流通交易

- **数据流通环境不够成熟**，成为制约数据要素市场建立的重要因素。目前，各地已先后成立了80余家数据交易机构，但场内交易并不活跃，也没有形成较为成熟可靠的制度规则。
- 比如，直接进行原始数据的买卖，存在数据来源不清的风险；开展数据撮合交易，存在既当运动员又当裁判员的问题。场外交易难监管、数据主体权益难保障，容易造成数据泄露和滥用，存在较大风险隐患，交易市场存在大量违法交易，严重影响了数据交易向纵深方向健康发展。
- 《规划》部署了2方面重点任务。**一是围绕数据确权与定价，鼓励市场主体探索数据资产定价机制，推动形成数据资产目录，逐步完善数据定价体系；开展数据确权及定价服务试验，探索建立数据资产登记制度和数据资产定价规则、试点开展数据权属认定，规范完善数据资产评估服务。二是围绕数据交易环境建设，培育规范的数据交易平台和市场主体，建立健全数据资产评估、登记结算、交易撮合、争议仲裁等市场运营体系；严厉打击数据违法交易，营造安全有序的市场环境。**

三、挖掘应用场景，创新数据要素开发利用机制

- 数字经济和实体经济的融合日益紧密，数据帮助制造业企业实现从“规模生产”到“规模定制”，有效支撑了个性化定制、体验式制造、网络制造等柔性化新型制造业态。在医疗、教育、交通等众多关乎民生的领域，数据要素的充分运用推动相关应用向数字化、智能化方向发展，促进提升人民生活的幸福感。数据要素的价值，越来越多地体现在促进降低生产成本、提高生产效率、改善生活水平等方面，要通过紧密围绕市场需求、应用需求，做到最大限度激发数据要素潜力。
- 《规划》提出，以实际应用需求为导向，探索建立多样化的数据开发利用机制。针对发挥不同主体的力量部署3方面任务。一是鼓励市场力量挖掘商业数据价值，推动数据价值产品化、服务化，大力发展专业化、个性化数据服务，促进数据、技术、场景深度融合，满足各领域数据需求。二是鼓励重点行业创新数据开放利用模式，在确保数据安全、保障用户隐私的前提下，调动行业协会、科研院所、企业等多方参与数据价值开发。三是对具有经济和社会价值、允许加工利用的政务数据和公共数据，通过数据开放、特许开发、授权应用等方式，鼓励更多社会力量进行增值开发利用。

财政部发布《企业数据资源相关会计处理暂行规定》

- 2023年8月21日，财政部制定印发了《企业数据资源相关会计处理暂行规定》（以下简称《暂行规定》），自2024年1月1日起施行。



财政部发布《企业数据资源相关会计处理暂行规定》

- **数据资产入表**

- 《暂行规定》有效回应了近年来企业关注的“数据资源是否可以作为资产确认、作为哪类资产确认和计量以及如何进行相关信息披露等相关会计问题”。
- 明确企业数据资源适用于现行企业会计准则，不改变现行准则的会计确认计量要求。通过针对数据资源制定专门统一规定，解决实务中对数据资源能否作为会计上的资产确认、作为哪类资产“入表”的疑虑，并明确计量基础。

财政部发布《企业数据资源相关会计处理暂行规定》

- 数据资产化将推动企业数字化转型
- 数据产权、流通交易、收益分配的一个前提就是要确认数据“资产”，只有在数据被确认为“资产”的前提下才可进行。《暂行规定》明确了数据资源可以作为无形资产或存货进行会计处理，也为相关行业和企业提供了统一的“数据入表”规则，促进数据资产的流动和共享。
- 《暂行规定》落地后，将有越来越多的企业通过多元化的方式对自己整体的数据进行盘点，确定哪些数据是可自用的、哪些可用作交易、哪些计为成本。同时预计企业也会同相关的数据估值、数据质量评估等专业化服务机构、相关的金融机构深度合作，做好自己的数据治理、包括“数据入表”、数据资产化的业务，综合看来，这将推动企业的数字化转型。

大数据与数据安全



什么是数据？

半结构化/非结构化数据

Web Clickstream



DOC / Media



Social Media



Machine / Sensor



Call Log



Apps



什么是大数据？

大数据(big data)，或称**巨量资料**，指的是所涉及的资料量规模巨大到无法透过目前主流软件工具，在合理时间内达到撷取、管理、处理、并整理成为帮助企业经营决策更积极目的的**资讯**。

对于“**大数据**”（Big data）研究机构Gartner给出了这样的定义。“大数据”是需要新处理模式才能具有更强的决策力、洞察发现力和流程优化能力来适应海量、高增长率和多样化的**信息资产**。

什么是大数据？

何为大？—数据度量

1 Byte = 8 Bit

1 KB = 1,024 Bytes

1 MB = 1,024 KB = 1,048,576 Bytes

1 GB = 1,024 MB = 1,048,576 KB = 1,073,741,824 Bytes

1 TB = 1,024 GB = 1,048,576 MB = 1,099,511,627,776 Bytes

1 PB = 1,024 TB = 1,048,576 GB = 1,125,899,906,842,624 Bytes

1 EB = 1,024 PB = 1,048,576 TB = 1,152,921,504,606,846,976 Bytes

1 ZB = 1,024 EB = 1,180,591,620,717,411,303,424 Bytes

1 YB = 1,024 ZB = 1,208,925,819,614,629,174,706,176 Bytes

什么是大数据？

数据没有办法在可容忍的时间下使用常规软件方法完成存储、管理和处理任务

《红楼梦》含标点87万字（不含标点853509字）

每个汉字占两个字节：1汉字=16bit = 2*8位=2bytes

1GB 约等于 671部红楼梦

1TB 约等于 631,903 部

1PB 约等于 647,068,911部

美国国会图书馆藏书（151,785,778册）（2011年4月：收录数据235TB）

中国国家图书馆：2631万册

1EB = 4000倍 美国国会图书馆存储的信息量

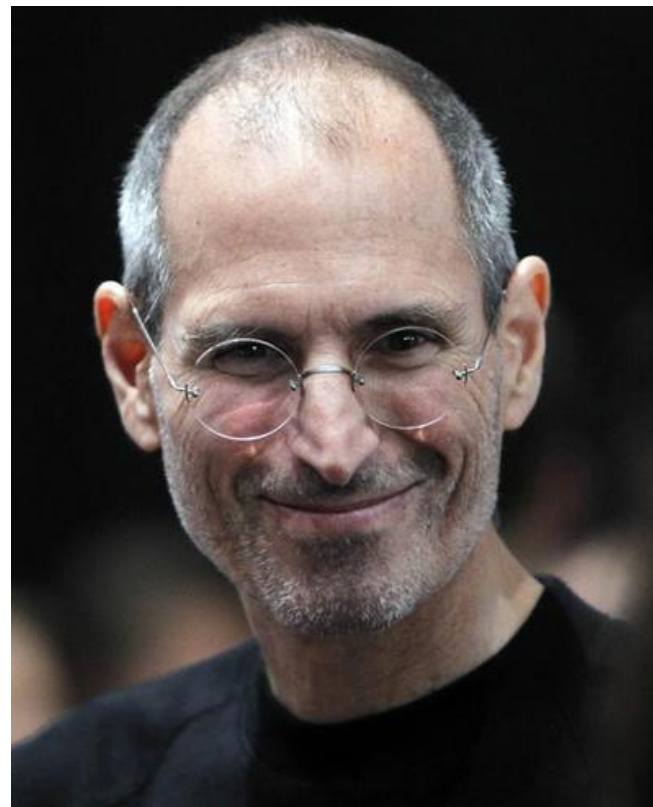
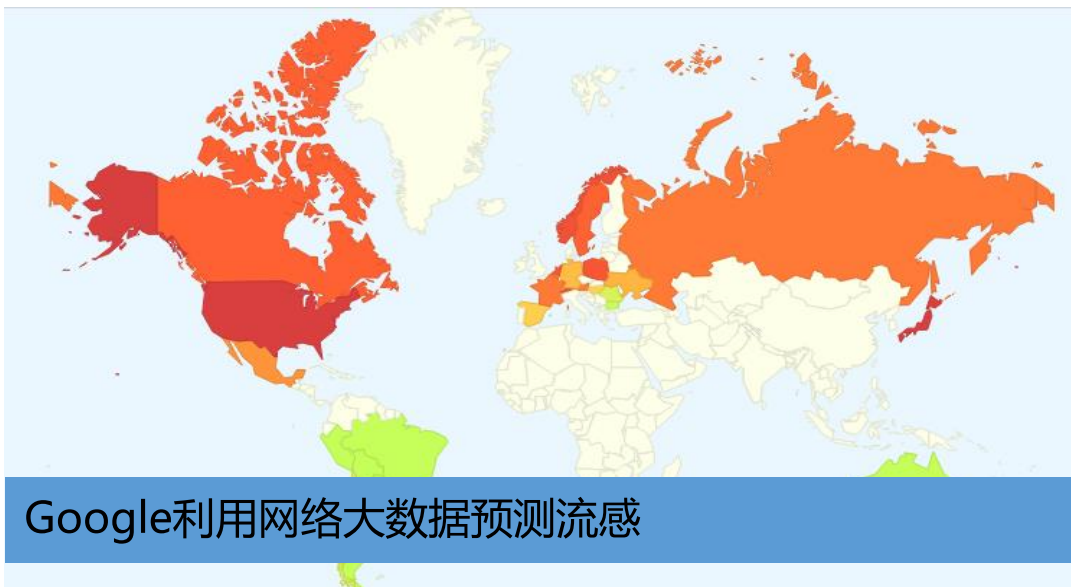
600美元的硬盘就可以存储全世界所有的歌曲

MGI估计,全球企业 2010 年在硬盘上存储了超过 7EB(1EB 等于 10 亿 GB) 的新数据,同时,消费者在 PC 和笔记本等设备上存储了超过 6EB 新数据

大数据带来的思维变革



大数据带来的思维变革（更多）



大数据商业价值——企业经营决策

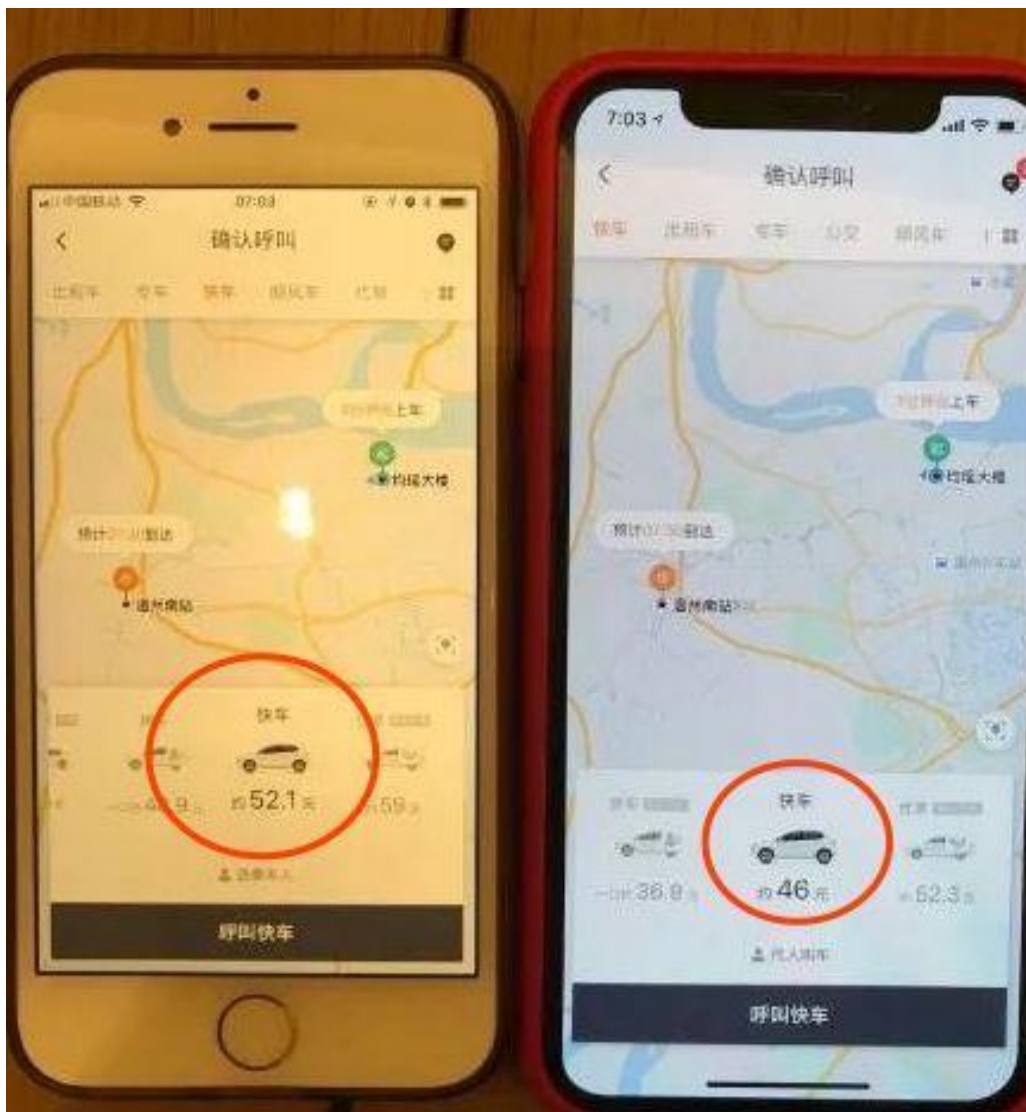


某商店卖牛奶，
通过数据分析，知道在本
店买了牛奶的顾客以后常
常会再去另一店买包子，
人数还不少，那么这家店
就可以考虑与包子店合作，
或直接在店里出售包子。



商场里啤酒和奶粉为什么在一个货架？

大数据杀熟



“杀熟”，即宰熟客，占熟人便宜。熟人，是指被掌握了信息的人，包括其行踪轨迹、个人喜恶等。基于这些信息制定有针对性的行为。

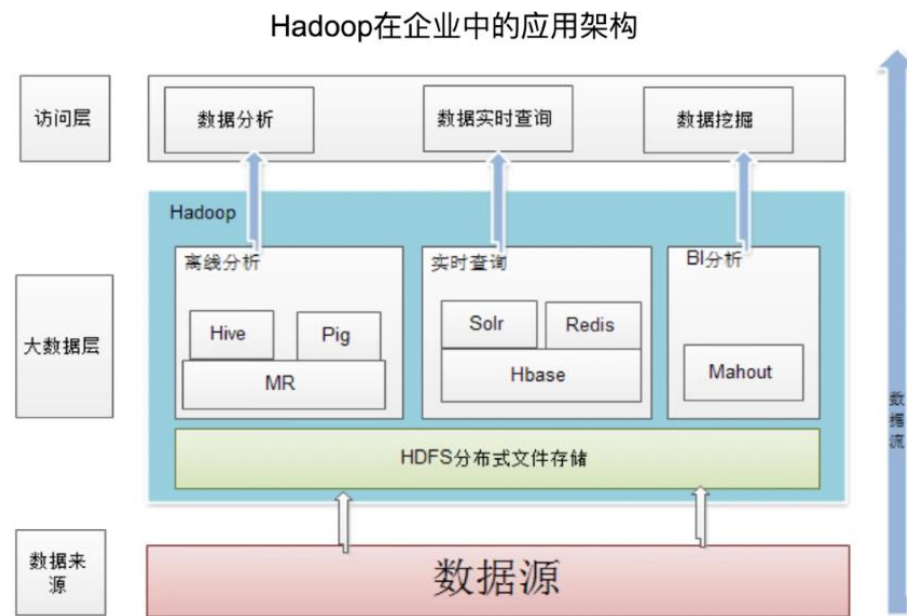
不能因大数据“杀熟”而杀死大数据

大数据涉及的关键技术

需求		技术	描述
海量数据存储技术		Hadoop, x86/MPP Map Reduce	分布式文件系统
实时数据处理技术		Streaming Data	流计算引擎
数据高速传输技术		Infini Band	服务器/存储间高速通信
数据分析技术 搜索技术		Enterprise Search	文本检索、智能搜索、 实时搜索

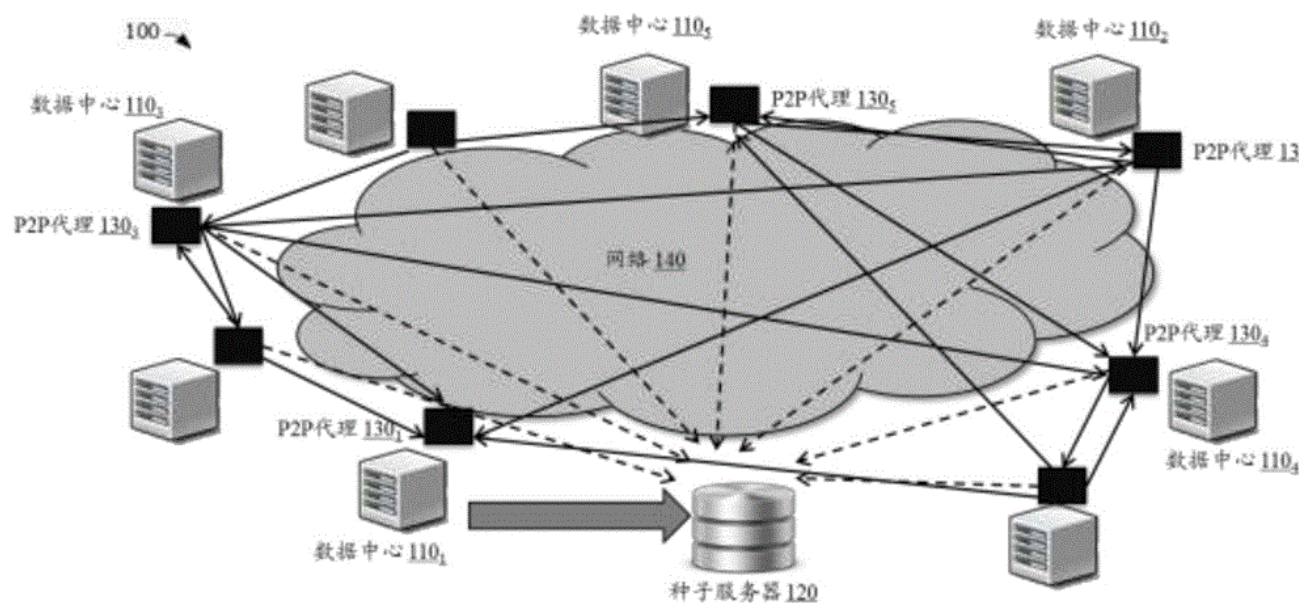
大数据安全防护：1安全的分布式计算框架

- Spark、Hadoop、MPI等分布式计算框架存在相当大的数据泄漏风险。
- 此外，它们还可能与不受信任的映射器关联。云安全联盟(CSA)建议企业使用认证方法并建立信任。
- 此外，必须反复灌输去识别，以确保隐私限制。
- 然后，企业必须验证对文件的访问权限，并确保敏感数据不会以任何方式泄露。



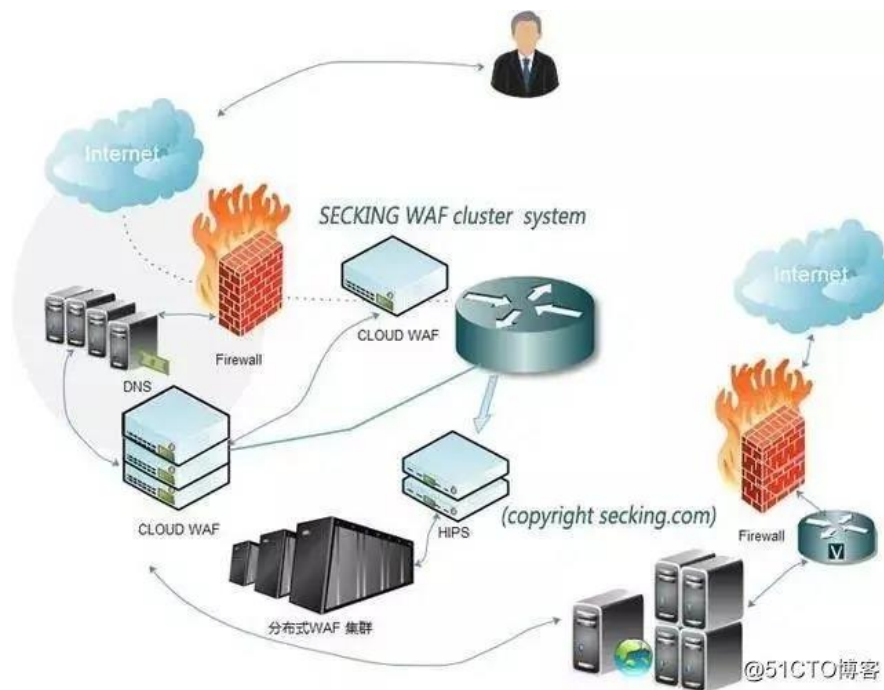
大数据安全防护：2安全数据存储

- 为了提高大数据的安全性，必须保证数据的安全存储。
- 为了保护数据存储，必须使用一种称为安全不可信任数据存储库的技术，监视来自第三方代理的未经授权的更改。



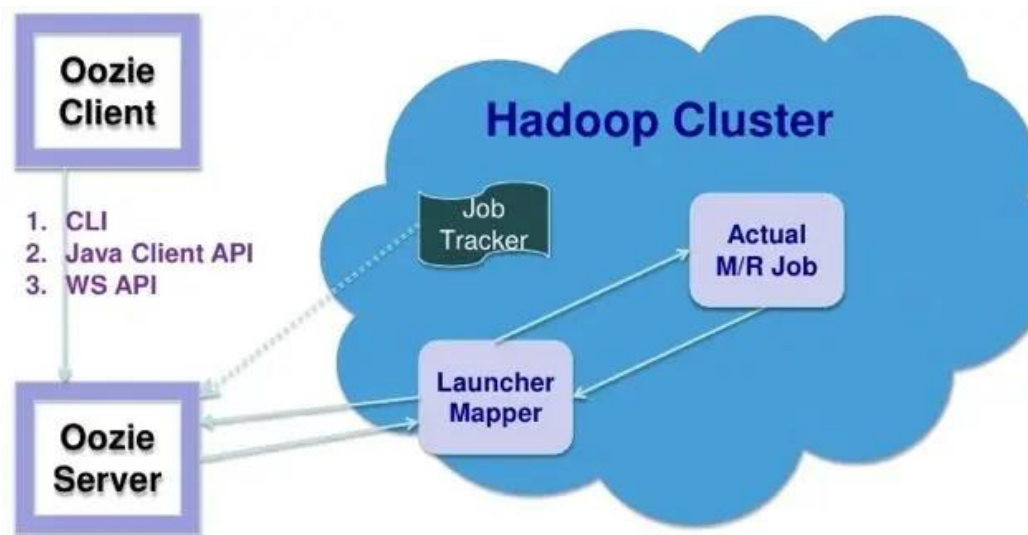
大数据安全防护：3保护你的数据

- 虽然企业通过吸收大量数据来改进其服务，但收集数据是一项艰巨且昂贵的任务。
- 为了保护您的数据，企业必须使用防火墙安全、入侵检测和预防工具、扫描工具，并要求对所有数据访问进行验证。



大数据安全防护：4加强审计

- 审计是大数据安全的必经之路，对审计数据要单独维护，以备日后参考。
- 在任何攻击后，企业都必须进行全面审计，以检查运行是否正常。像ApacheOozie等技术有助于更好地理解大数据集群。



大数据安全防护：5安全的硬件和软件配置

- 在任何企业中，硬件或软件故障都是导致数据丢失的重要原因之一。
- 因此，企业必须通过定期更新来管理硬件和软件配置。防止数据泄露是企业文化中不断灌输的一个过程，即使用可扩展的大数据分析工具。
- 企业必须保护自己的大数据平台不受威胁，才能多年不间断地为企业服务。



数据安全技术与发展

数据安全技术

- (1)用户标识和鉴别
- 该方法由系统提供一定的方式让用户标识自己咱匀名字或身份。每次用户要求进入系统时，由系统进行核对，通过鉴定后才提供系统的使用权。
- (2)存取控制
- 通过用户权限定义和合法权检查确保只有合法权限的用户访问数据库，所有未被授权的人员无法存取数据。例如C2级中的自主存取控制(I)AC)，BI级中的强制存取控制(M：AC)。
- (3)视图机制
- 为不同的用户定义视图，通过视图机制把要保密的数据对无权存取的用户隐藏起来，从而自动地对数据提供一定程度的安全保护。
- (4)审计
- 建立审计日志，把用户对数据库的所有操作自动记录下来放入审计日志中，DBA可以利用审计跟踪的信息，重现导致数据库现有状况的一系列事件，找出非法存取数据的人、时间和内容等。
- (5)数据加密
- 对存储和传输的数据进行加密处理，从而使得不知道解密算法的人无法获知数据的内容。

数据泄露防护技术

- 数据泄露 (Data Leakage), 数据泄露防护 (Data Leakage Protection, DLP)



数据防泄露技术与方法

• 一、加强密码管理

- 密码是保护个人和企业信息安全的第一道防线。合理的密码策略能够有效减少被破解的风险。首先,密码应该足够复杂,包含大小写字母、数字和特殊字符,并且长度不少于8位。其次,密码应定期更换,避免长时间使用相同的密码。
- 最后,不同的账户应使用不同的密码,避免一次泄露导致多个账户被攻破。

• 二、加密敏感数据

- 对于存储在服务器或云端的敏感数据,我们应该采取加密措施,确保即使被攻击者获取,也无法解读其内容。常见的加密方式包括对称加密和非对称加密。对称加密使用相同的密钥进行加解密,而非对称加密则使用公钥和私钥进行加解密。合理选择加密算法,并定期更新密钥,能够提高数据的安全性。

• 三、建立访问控制机制

- 访问控制是防止未经授权的人员访问敏感数据的重要手段。通过建立用户身份验证机制,限制不同用户对数据的访问权限,可以有效减少数据泄露的风险。例如,可以使用双因素认证,要求用户在输入用户名和密码之外,还需提供一次性验证码或指纹等信息。此外,及时撤销离职员工的访问权限也是重要的一环。

• 四、加强网络安全监控

- 网络安全监控是及时发现并阻止数据泄露的重要手段。通过安装入侵检测系统(IDS)和入侵防御系统(IPS),能够实时监控网络流量,识别潜在的攻击行为,并采取相应的防御措施。此外,定期进行安全漏洞扫描和渗透测试,发现并修补系统中存在的漏洞,也是防止数据泄露的重要措施。

• 五、加强员工安全意识教育

- 员工是企业信息安全的重要环节,因此加强员工的安全意识教育至关重要。通过定期组织网络安全的培训,教育员工识别垃圾邮件、钓鱼网站等网络攻击手段,提高他们对网络安全的警惕性。同时,建立规范的操作流程和安全政策,明确员工在处理敏感数据时的责任和义务,能够有效减少数据泄露的风险。

个人数据安全保护

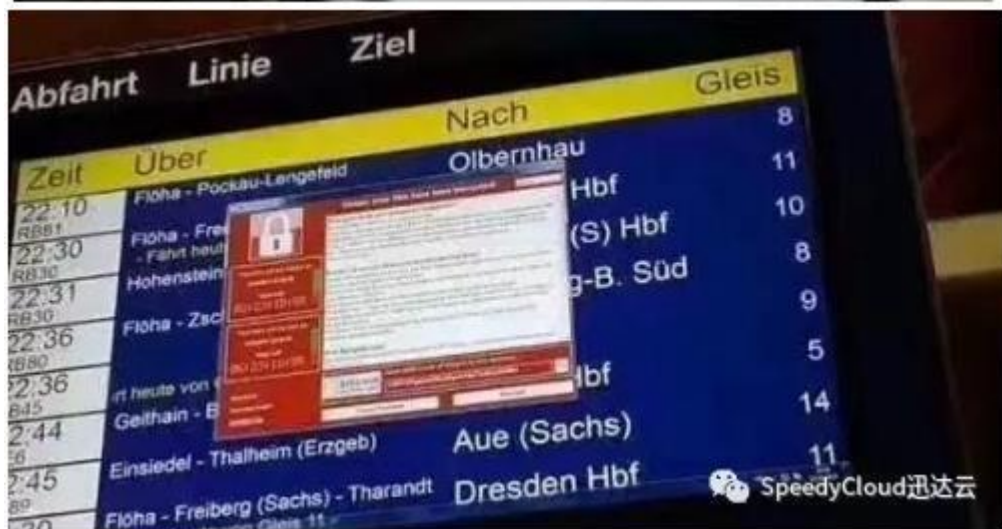
- 加密与解密
- 文档安全删除

勒索病毒 “WannaCry”

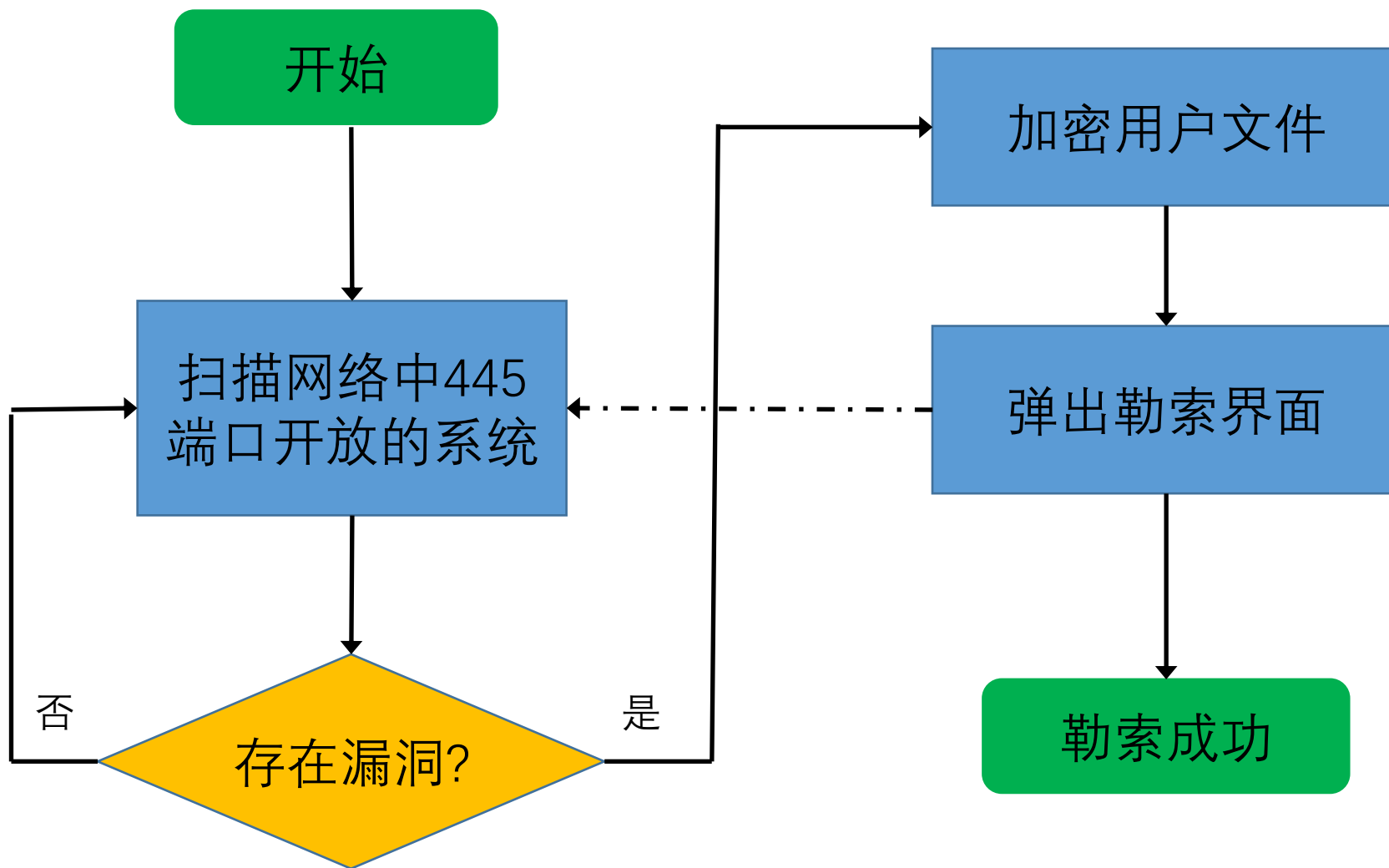
- 2017年5月，席卷全球的WannaCry勒索病毒已经扩散至100多个国家和地区，包括医院，教育机构，政府部门都无一例外的遭受到了攻击。



勒索病毒 “WannaCry”



WannaCryptor攻击流程



“WannaCry” 的传播

- 该病毒利用Windows系统的“永恒之蓝”，这个漏洞传播，几乎所有没打补丁的Windows系统都会被攻击。
- Wannacry勒索病毒攻击，主要针对windows7、windows8、windowsXP。
- iOS、Android和windows10不受影响

Microsoft 安全公告 MS17-010 - 严重

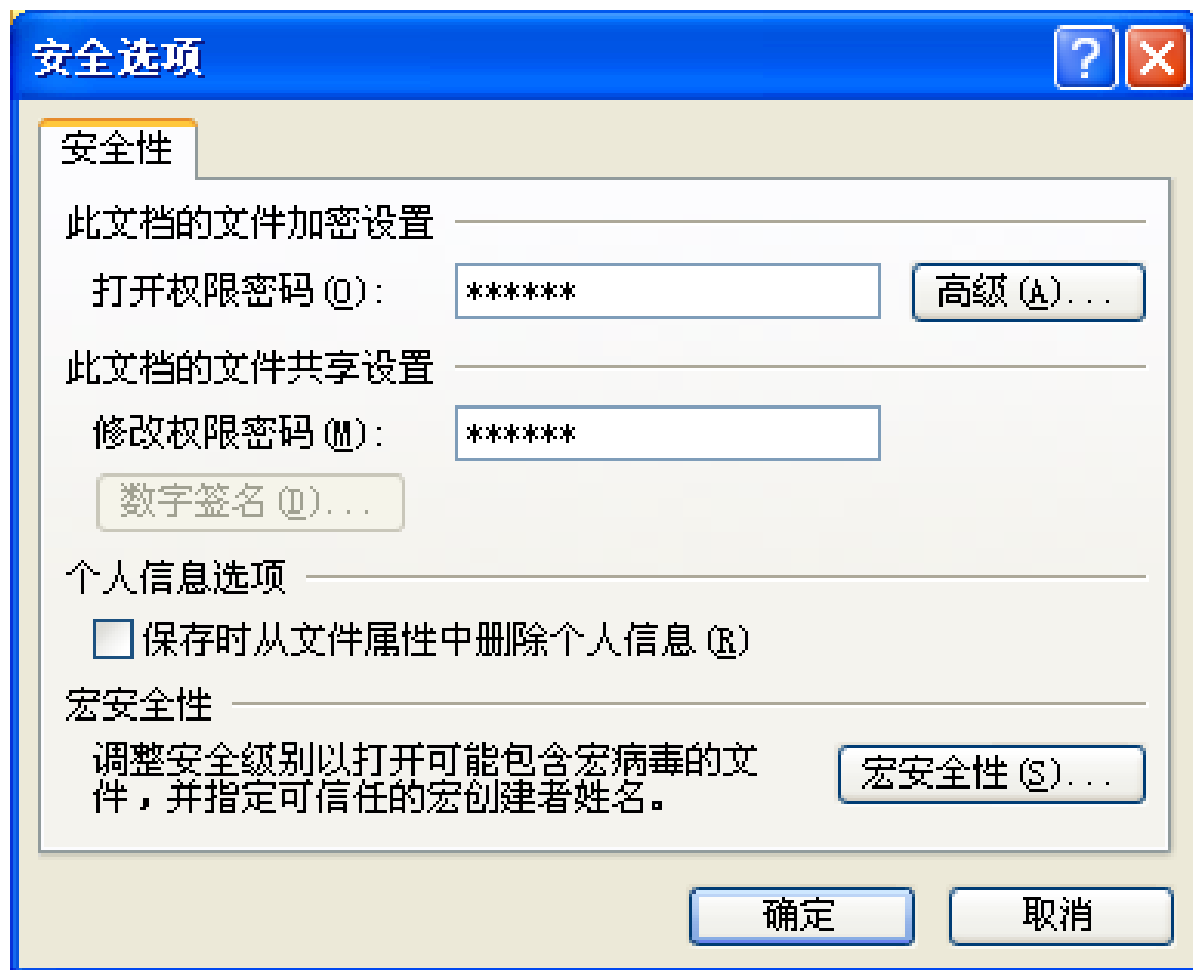
Microsoft Windows SMB 服务器安全更新 (4013389)

发布日期：2017 年 3 月 14 日

版本：1.0

Office文档加密

- 适用范文：WORD、PPT、EXCEL等Office文档



弱口令

排名	密码	数量	占比	累计占比
1	12345678	3048	3.256%	3.256%
2	123456789	2460	2.628%	5.885%
3	88888888	1453	1.552%	7.437%
4	1234567890	711	0.760%	8.197%
5	00000000	406	0.434%	8.631%
6	87654321	351	0.375%	9.006%
7	66668888	335	0.358%	9.363%
8	11223344	316	0.338%	9.701%
9	147258369	313	0.334%	10.035%
10	11111111	299	0.319%	10.355%

密码字典

- 10位数字
- 400W常用密码
- wordlist
- WPA英文字典
- 超级字典
- 弱口令集
- 生日1980-2010年
- 真空密码字典生成器 2.5 绿色版
- (1-100W).TXT
- (101W-200W).TXT
- (201W-300W).TXT
- (301W-400W).TXT
- (401W-500W).TXT
- 0-9.8位纯数密码.txt
- 3+sr.txt
- 123.txt
- 133127.txt
- 142183.txt
- 14365003.txt
- all_birth(vip).txt
- Beini-1.1 中的新字典.txt
- bir.txt
- DICT 213560 条记录.TXT
- fcicq-dict-unidict-20100410.txt
- name_cn.txt
- PassWord2.txt
- wordlist(spoonwpa自带字典).txt
- wordlist.TXT
- wordlist1.txt
- wordlistBT4.txt
- 百家姓+年月日.txt
- 很全的路由器默认初始密码集合.txt
- 两个字母+单一数字.txt
- 名字拼音.txt
- 拼音_数字.txt
- 前面一个字母+生日50-00.txt
- 三字母+单一数字.txt
- 手机号密码字典.txt

中国人常用的密码字典 破率70%以上



这个是中国人常用的密码字典 破率70%以上 欢迎下载,如果不成功可以用我的其它字典 专业解决破解问题

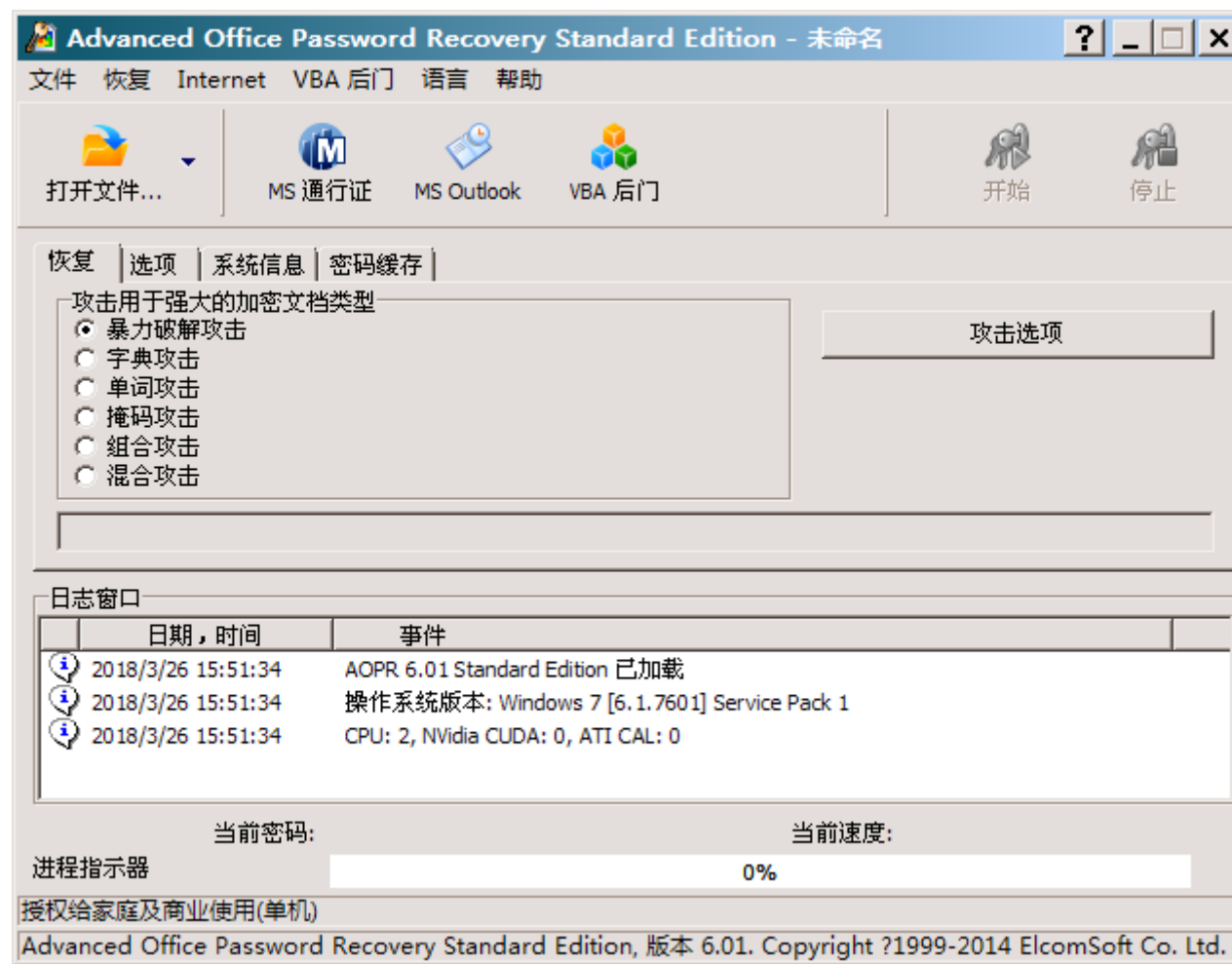
中国人常用的密码字典

所需积分/C币: 40

上传时间: 2012-04-01

资源大小: 36KB

Office文档解密



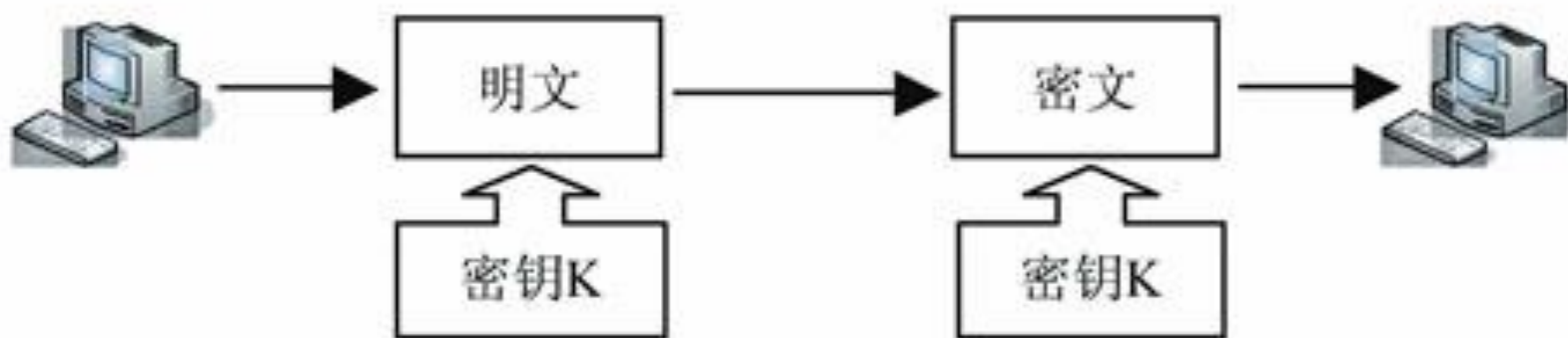
其它加密方法

- WinRAR加密



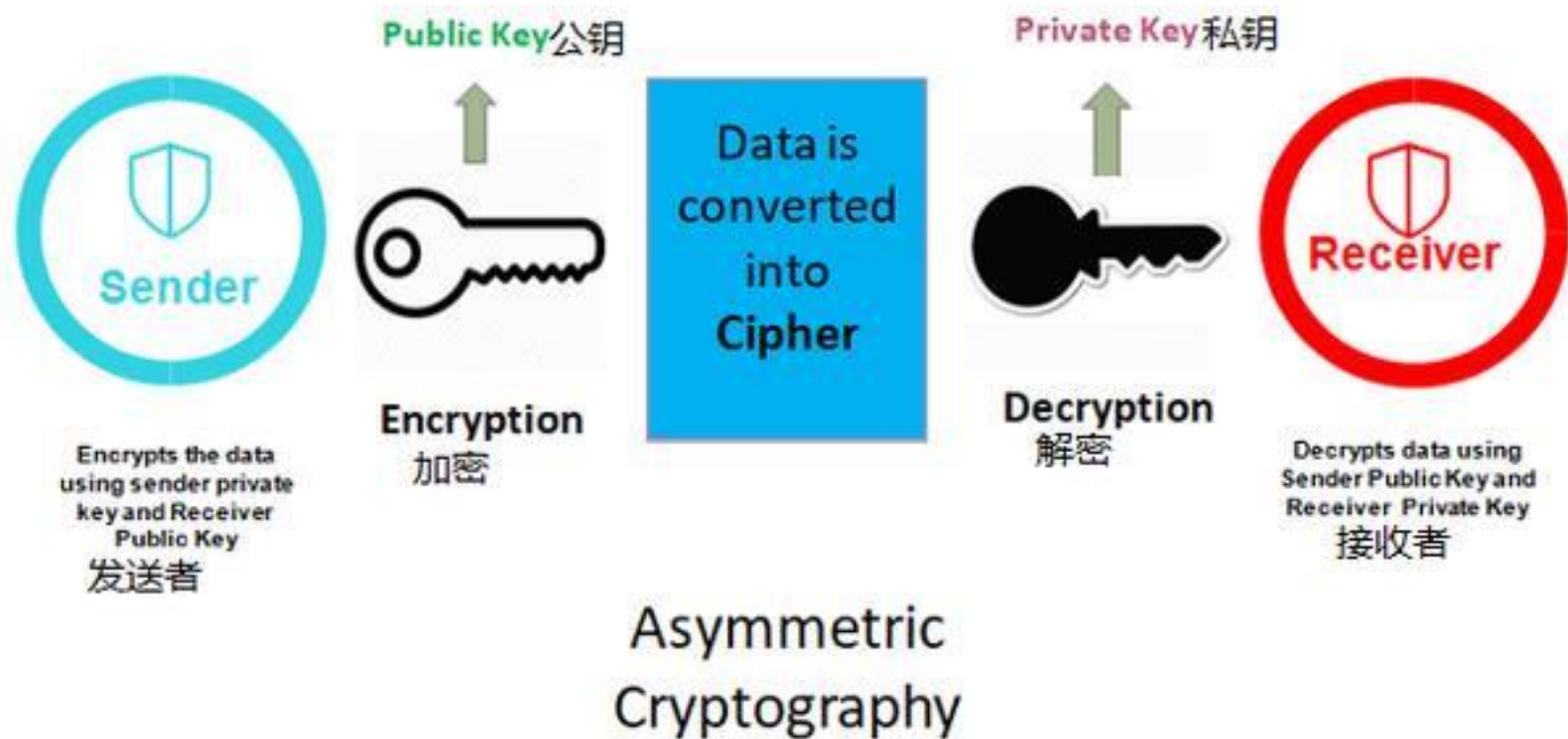
对称加密

- 采用单钥密码系统的加密方法，同一个密钥可以同时用作信息的加密和解密，这种加密方法称为对称加密，也称为单密钥加密。



非对称加密

- 对称加密算法在加密和解密时使用的是同一个密钥；而非对称加密算法需要两个密钥来进行加密和解密，这两个密钥是公开密钥（public key，简称公钥）和私有密钥（private key，简称私钥）。



其它加密方法

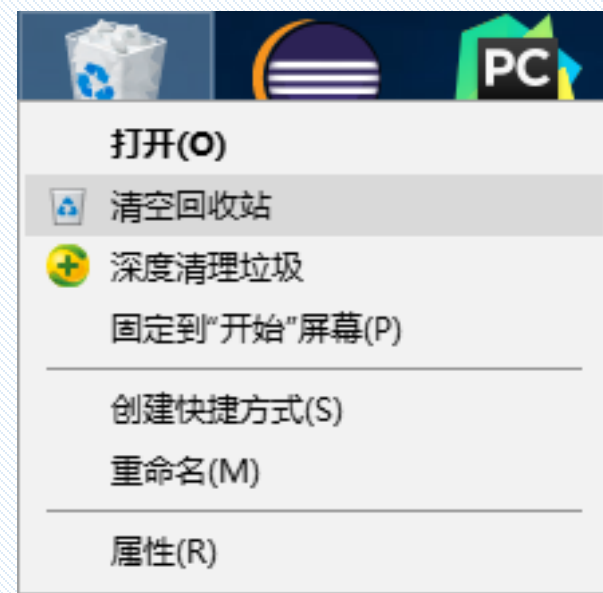
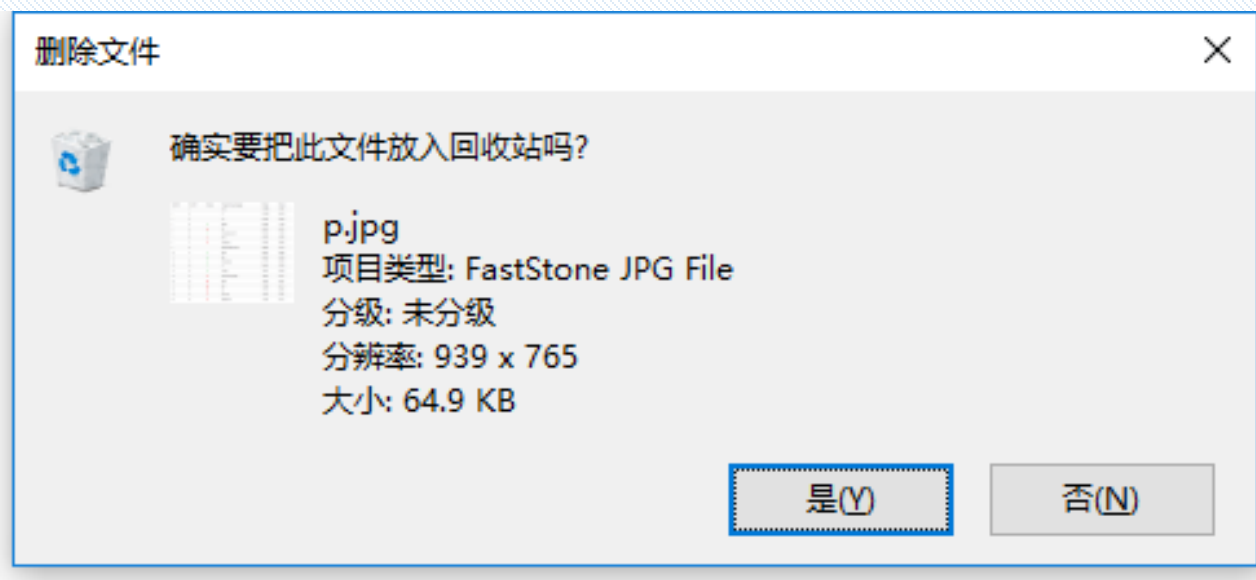
- **PGP加密**
- PGP加密系统是采用公开密钥加密与传统密钥加密相结合的一种加密技术。
- 它使用一对数学上相关的钥匙，其中一个（公钥）用来加密信息，另一个（私钥）用来解密信息。PGP采用的传统加密技术部分所使用的密钥称为“会话密钥”（sek）。
- 每次使用时，PGP都随机产生一个128位的IDEA会话密钥，用来加密报文。
- 公开密钥加密技术中的公钥和私钥则用来加密会话密钥，并通过它间接地保护报文内容。

PGP Desktop



文件安全删除

- 回收站是微软Windows操作系统里的其中一个系统文件夹，主要用来存放用户临时删除的文档资料，存放在回收站的文件可以恢复。



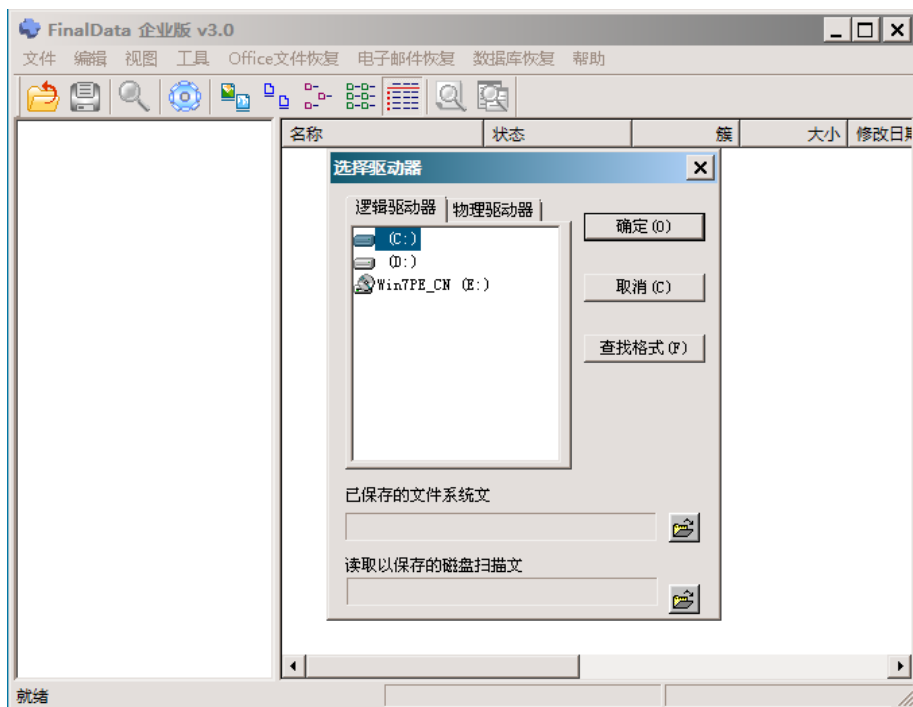
EasyRecovery

- Easyrecovery用起来确实很Easy，但是功能也很“Easy”作为数据恢复界的类似于普及版的软件，作为恢复删除后的数据还是挺不错的，但是相比于同类的易我恢复等软件来说就相对而言比较“Easy”了



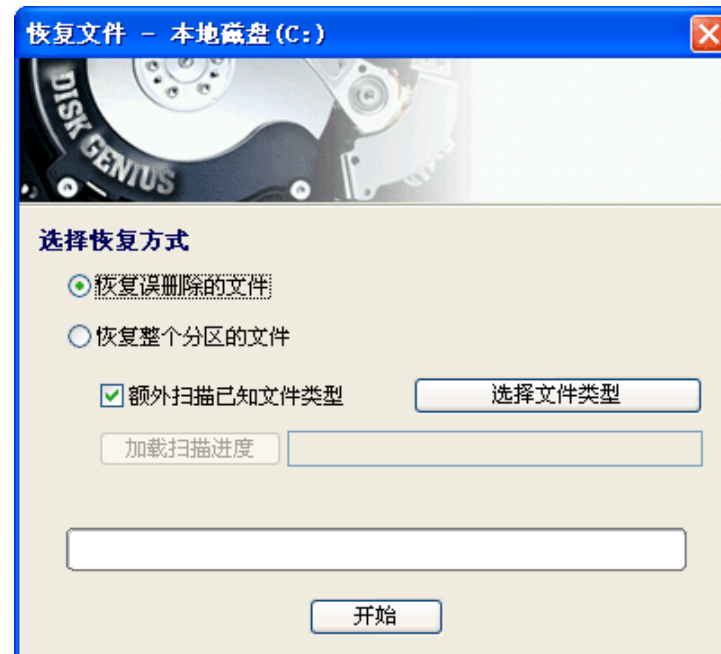
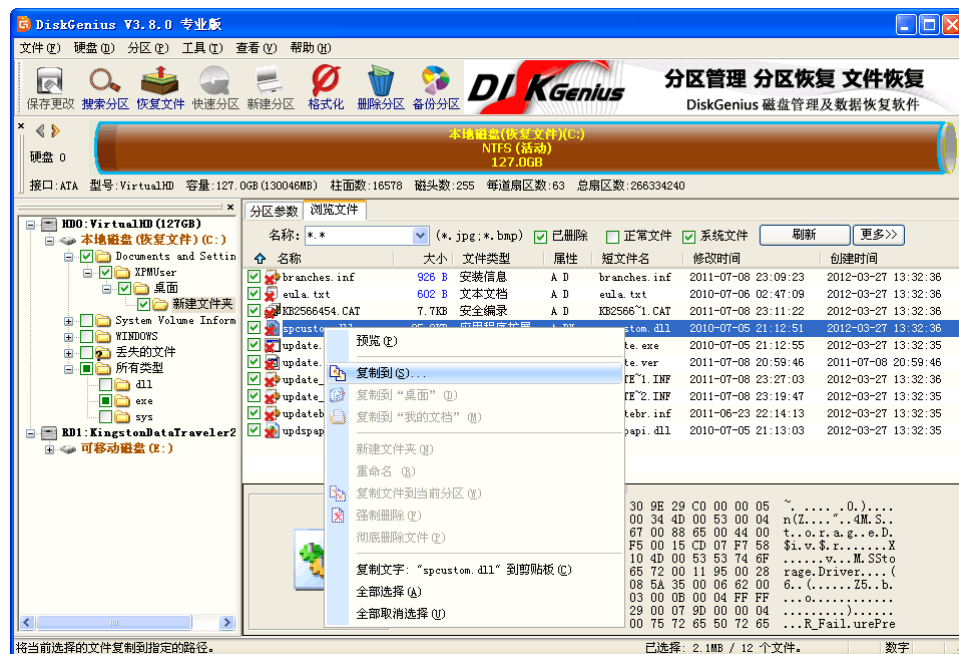
Finaldata

- Finaldata这个软件多用于PE系统中，使用较简单，但是功能上不太好用，而且速度比较慢，但是由于其在PE下的广泛应用，这也是值得注意的



DiskGenius

- 一款硬盘分区及数据恢复软件。它是在最初的DOS版的基础上开发而成的。Windows版本的DiskGenius软件，除了继承并增强了DOS版的大部分功能外(少部分没有实现的功能将会陆续加入)，还增加了许多新的功能。如：已删除文件恢复、分区复制、分区备份、硬盘复制等功能。



思考题

- 处理过重要文档的硬盘是否可以直接丢弃？
- 保存过重要文件的硬盘报废前如何处理？



安全事件管理与应对

应急预案制定与管理

● 应急预案制定



应急预案制定的阶段

- 应急响应需求分析和应急响应策略的确定
- 编制应急响应计划文档
- 应急响应计划的测试、培训、演练和维护

周而复始

持续改进



制定应急预案（ERP）的目的

- 建立健全网络安全突发事件的应急组织体系和工作机制；
- 提高事件综合应对能力；
- 确保及时有效地控制、减轻和消除事件造成的社会危害和损失；
- 保证业务持续稳定运行和数据安全。

应急预案制定与管理

● 应急预案制定



应急预案的主要内容

- 总则
- 角色及职责
- 预防和预警机制
- 应急响应流程
- 应急响应保障措施
- 附件



应急预案的制定原则

- 完整性
- 易用性
- 明确性
- 有效性
- 兼容性

信息安全事件 Information security incident

- 信息安全事件是由单个或一系列意外或有害的信息安全事态所组成的，极有可能危害业务运行和威胁信息安全。
- 常见的信息安全事件有：

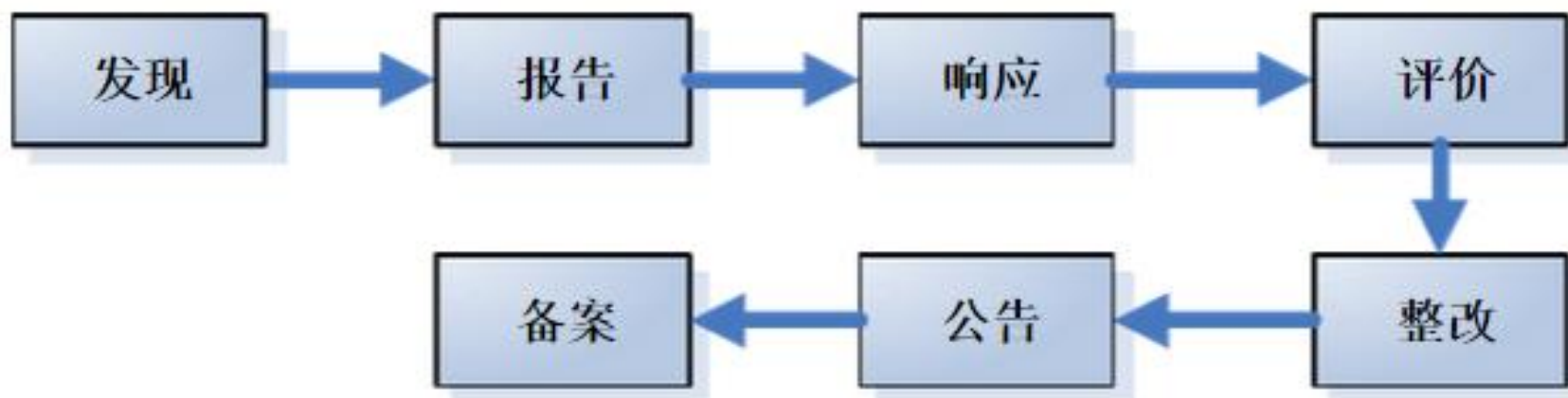
服务器或主要网络设备软硬件故障、服务器异常停机、电力中断、水灾、火灾等重大灾害、重大恶性计算机病毒传播、大规模黑客入侵、重大信息安全漏洞、重要业务数据丢失或被篡改、重大信息安全投诉、人为的故意破坏等影响严重到公司正常业务运作，造成或极可能造成公司业务活动中断、机密信息泄露的事件等。

管理人员职责

- 信息安全领导小组负责批准、发布本管理程序；听取信息安全事故分析报告，并做出决策。
- 信息安全工作小组负责组织编写本管理程序，并且引导相关部门及人员落实实施；发生重大安全事故时应及时向信息安全领导小组进行汇报；负责督促信息安全事故整改措施的落实。
- 信息安全执行小组负责按照信息安全事故处理流程进行事故处理。
- 各部门负责本部门信息安全事故的逐级上报；负责配合信息安全执行小组进行信息安全事故的调查分析，提交事故分析报告，并确保预防或改进措施的落实。

信息安全事件处理流程

- 信息安全事件的处理流程主要包括：发现、报告、响应（处理）、评价、整改、公告、备案等。



谢谢！